



UNIVERSIDADE
LUSÓFONA

Auditoria ISO 27001

Licenciatura em Engenharia Informática

Projeto II

Relatório

2º Semestre

Daniel Filipe Ramos de Carvalho, a22209980

Orientador: Hugo Barbosa

Departamento de Engenharia Informática e Sistemas de Informação Universidade
Lusófona, Centro Universitário do Porto (CUP)

Maio 2026

www.ulusofona.pt

Direitos de cópia

Auditoria ISO 27001, Copyright de *Daniel Filipe Ramos de Carvalho*, Universidade Lusófona.

A Faculdade de Ciências Naturais, Engenharia e Tecnologias (FCNET) e a Universidade Lusófona têm o direito, perpétuo e sem limites geográficos, de arquivar e publicar esta dissertação/monografia através de exemplares impressos reproduzidos em papel ou de forma digital, ou por qualquer outro meio conhecido ou que venha a ser inventado, e de a divulgar através de repositórios científicos e de admitir a sua cópia e distribuição com objetivos educacionais ou de investigação, não comerciais, desde que seja dado crédito ao autor e editor.

Agradecimentos

Chegar ao fim deste Trabalho Final de Curso é o fecho de uma etapa gigante, tanto a nível de estudos como pessoal. Este projeto não é só meu, é o resultado da ajuda de muita gente que me deu força pelo caminho e a quem tenho de deixar um obrigado sincero.

Primeiro, um agradecimento especial ao meu orientador, o Professor Hugo Barbosa.

À Universidade Lusófona e a todos os professores com quem cruzei. Obrigado por partilharem o que sabem e por me darem as bases para conseguir resolver os problemas que foram aparecendo neste projeto (e não foram poucos).

Aos meus pais e à minha família, o maior obrigado de todos.

Aos meus amigos e colegas de curso.

Por fim, a toda a gente que, de uma maneira ou de outra, me deu uma palavra de apoio ou me ajudou a chegar aqui, o meu muito obrigado.

Resumo

A conformidade com a norma ISO/IEC 27001 representa um desafio significativo para pequenas e médias empresas, limitadas pela complexidade técnica e pelos elevados custos associados a consultorias. Para mitigar este problema, foi desenvolvida uma plataforma web orientada à simplificação e digitalização do ciclo de auditoria. A metodologia baseou-se na implementação de uma arquitetura Cliente-Servidor desacoplada, utilizando a biblioteca React para a interface e a framework Django para a API REST, com suporte em base de dados MySQL. A solução integra checklists automáticas baseadas nos 93 controles do Anexo A, monitorização em tempo real do estado de conformidade (Statement of Applicability) e geração de planos de ação corretiva assistidos por Inteligência Artificial. Os testes realizados em ambiente cloud demonstraram a eficácia do sistema na centralização de evidências e na mitigação de falhas de segurança. Conclui-se que a plataforma reduz os custos operacionais e a carga burocrática, tornando o processo de preparação para a certificação mais acessível e organizado.

Palavras-chave: Segurança da Informação; ISO/IEC 27001; Auditoria; Conformidade; Inteligência Artificial.

Abstract

Compliance with the ISO/IEC 27001 standard represents a significant challenge for small and medium-sized enterprises, limited by technical complexity and high consulting costs. To mitigate this problem, a web platform was developed aimed at simplifying and digitizing the audit cycle. The methodology was based on the implementation of a decoupled Client-Server architecture, using the React library for the interface and the Django framework for the REST API, supported by a MySQL database. The solution integrates automatic checklists based on the 93 controls of Annex A, real-time monitoring of compliance status (Statement of Applicability), and the generation of corrective action plans assisted by Artificial Intelligence. Tests conducted in a cloud environment demonstrated the system's effectiveness in centralizing evidence and mitigating security flaws. It is concluded that the platform reduces operational costs and bureaucratic burden, making the preparation process for certification more accessible and organized.

Keywords: Information Security; ISO/IEC 27001; Audit; Compliance; Artificial Intelligence

Índice

Resumo	4
Índice.....	6
1 Introdução	
.....	
12	
1.1 Enquadramento	
.....	1 2
1.2 Motivação e Identificação do Problema	
.....	13
1.3 Objetivos	
.....	
13	
2 Pertinência e Viabilidade	
.....	14
2.1 Pertinência	
.....	14
2.2 Viabilidade	
.....	14
2.3 Análise Comparativa com Soluções Existentes	
.....	15
2.3.1 Soluções existentes	
.....	15
2.3.2 Análise de benchmarking	
.....	15
2.4 Proposta de inovação e mais-valias	
.....	17
2.5 Identificação de oportunidade de negócio	
.....	18
3 Especificação e Modelação	
.....	18
3.1 Análise de Requisitos	
.....	18

3.1.1	Requisitos Funcionais	19
3.1.2	Requisitos Não-Funcionais	20
3.1.3	Casos de Uso	26
3.2	Modelação	2
3.3	Protótipos de Interface	30
4	Solução Desenvolvida	31
4.1	Introdução	31
4.2	Arquitetura	31
4.3	Tecnologias e Ferramentas Utilizadas	33
4.4	Ambientes de Teste e de Produção	34
4.5	Abrangência	35
4.6	Componentes	36
4.6.1	Componente 1	36
4.6.2	Componente 2	
4.7	Interfaces	39
5	Testes e Validação	56
6	Método e Planeamento	57
7	Resultados	59

7.1 Resultados dos Testes 59

7.2 Cumprimento de requisitos 60

8 Conclusão 63

8.1 Conclusão 63

8.2 Trabalhos Futuros 64

Bibliografia 65

Anexo 1 – Recomendações para formatação de um relatório 66

Anexo 2 – Recomendações para formatação de um relatório 87

Lista de Figuras

Figura 1 - Benchmarking

Lista de Siglas

API	Interface de Programação de Aplicações
HTML	Linguagem de Marcação de Hipertexto
PME	Pequenas Médias Empresas

1 Introdução

Muitas organizações de pequena escala possuem a necessidade de demonstrar segurança aos seus clientes, mas não tem tantos recursos financeiros para consultorias externas dispendiosas. Sem uma ferramenta de apoio, estas empresas acabam por ter processos de segurança desorganizados e dificuldades em passar auditorias de certificação.

Profissionais que estão a dar os primeiros passos na área da cibersegurança enfrentam frequentemente a complexidade da norma sem uma estrutura de apoio prática. A necessidade de verificar múltiplos controlos (como proteção contra malware ou políticas de segurança) de forma manual aumenta o risco de erro e a omissão de evidências críticas.

Link Youtube:

<https://www.youtube.com/playlist?list=PLINeKvdsJRYsJ7nAsQ6T9NbA8P2iELODE>

Link github :

<https://github.com/danizainz/auditoria-iso-27001>

1.1 Enquadramento

Este trabalho situa-se no domínio da Gestão de Segurança da Informação, área que se tornou vital devido à crescente dependência digital das organizações e às mais ameaças cibernéticas. A relevância deste estudo reside na necessidade de facilitar o acesso a normas internacionais de segurança, permitindo que entidades com recursos limitados estejam em conformidade com os requisitos.

Os conceitos centrais em torno dos quais o trabalho versa são:

Segurança da Informação: É a preservação da confidencialidade, integridade e disponibilidade da informação. Baseia-se em garantir que dados sensíveis sejam armazenados de forma segura e acessíveis apenas a pessoal autorizado.

Norma ISO 27001: É o padrão internacional que descreve os requisitos para um Sistema de Gestão de Segurança da Informação (SGSI). Funciona através da aplicação de controlos específicos que visam mitigar riscos organizacionais.

Auditoria de Conformidade: É o processo sistemático de verificar se uma organização cumpre os requisitos e controlos definidos pela norma. Utiliza ferramentas como checklists para avaliar o grau de alinhamento com as boas práticas.

PME (Pequenas e Médias Empresas): No contexto deste estudo, representam o público-alvo que frequentemente carece de recursos técnicos ou financeiros para implementar normas complexas de segurança.

1.2 Motivação e Identificação do Problema

Explicar as motivações que levam a propor o presente trabalho, evidenciando por que o tema é importante ou interessante, podendo incluir motivações pessoais ou sociais para a pesquisa. Definir o problema que que se pretende resolver ou explorar.

1.3 Objetivos

O objetivo geral deste projeto é desenvolver uma plataforma web educativa e funcional que simplifique a realização de auditorias e a aprendizagem da norma ISO 27001 para pequenas empresas e profissionais da área.

- Implementar um sistema de gestão de utilizadores com diferentes perfis de acesso e permissões.
- Desenvolver checklists automáticas baseadas nos controlos da norma para verificar o nível de conformidade.
- Criar painéis de controlo para visualização em tempo real do progresso das auditorias e indicadores de conformidade.
- Implementar a geração automática de relatórios de conformidade com base nas respostas submetidas.
- Disponibilizar uma biblioteca de recursos educativos e exemplos práticos sobre os requisitos da norma.

2 Pertinência e Viabilidade

2.1 Pertinência

Demonstrar que o trabalho em desenvolvimento tem impacto positivo e contribui para a resolução do problema identificado no capítulo anterior. Incluir validação por terceiros, como avaliações ou opiniões de especialistas, e descrever o impacto positivo esperado do projeto na resolução do problema. Criar um inquérito de pertinência e viabilidade da solução proposta (a incluir como anexo), permitindo validar as principais ideias por detrás das motivações, do problema identificado e da solução proposta, apresentando nesta secção os principais resultados sob a forma de gráficos, acompanhados de uma discussão.

2.2 Viabilidade

Viabilidade é a medida em que uma solução pode ser implementada e sustentada com sucesso. A viabilidade deverá ser avaliada por critérios econométricos, demonstrando-se que a solução proposta terá características para poder ser continuada após conclusão do TFC, não se esgotando enquanto projeto académico.

2.3 Análise Comparativa com soluções existentes

2.3.1 Soluções existentes

Atualmente existem diversas soluções no mercado que apoiam a gestão da segurança da informação e a conformidade com a norma ISO/IEC 27001, sendo a maioria orientada para organizações de média e grande dimensão, com custos elevados e maior complexidade. Seguem-se algumas das soluções mais relevantes.

ISMS.online é uma plataforma comercial para apoio à implementação e gestão de Sistemas de Gestão da Segurança da Informação (SGSI), incluindo funcionalidades de auditoria, gestão documental e controlo de conformidade, apresentando custos elevados e elevada complexidade.

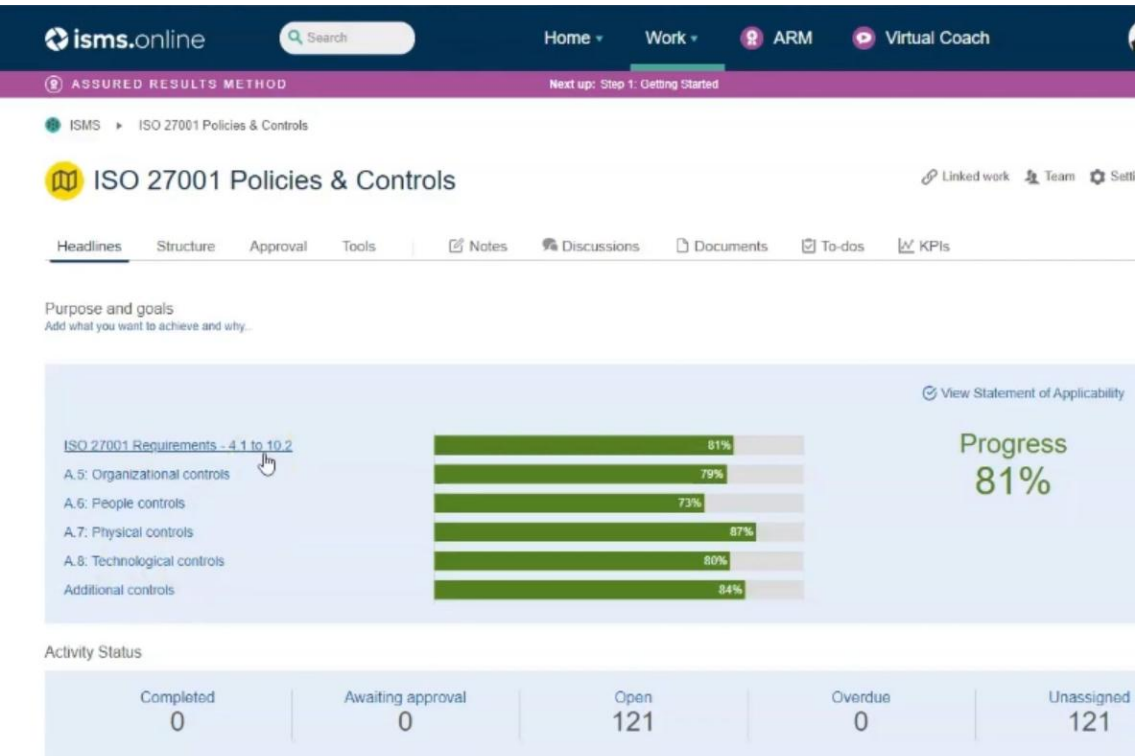


Figura 2 - Benchmarking 1

Vanta é uma solução focada na automação da conformidade com várias normas de segurança, incluindo a ISO 27001, baseada em integrações técnicas e recolha automática de evidências, sendo pouco acessível para pequenas organizações.

Secureframe é uma plataforma que apoia a conformidade com normas de segurança através de workflows automatizados, gestão de evidências e relatórios de auditoria, direcionada sobretudo para empresas tecnológicas.

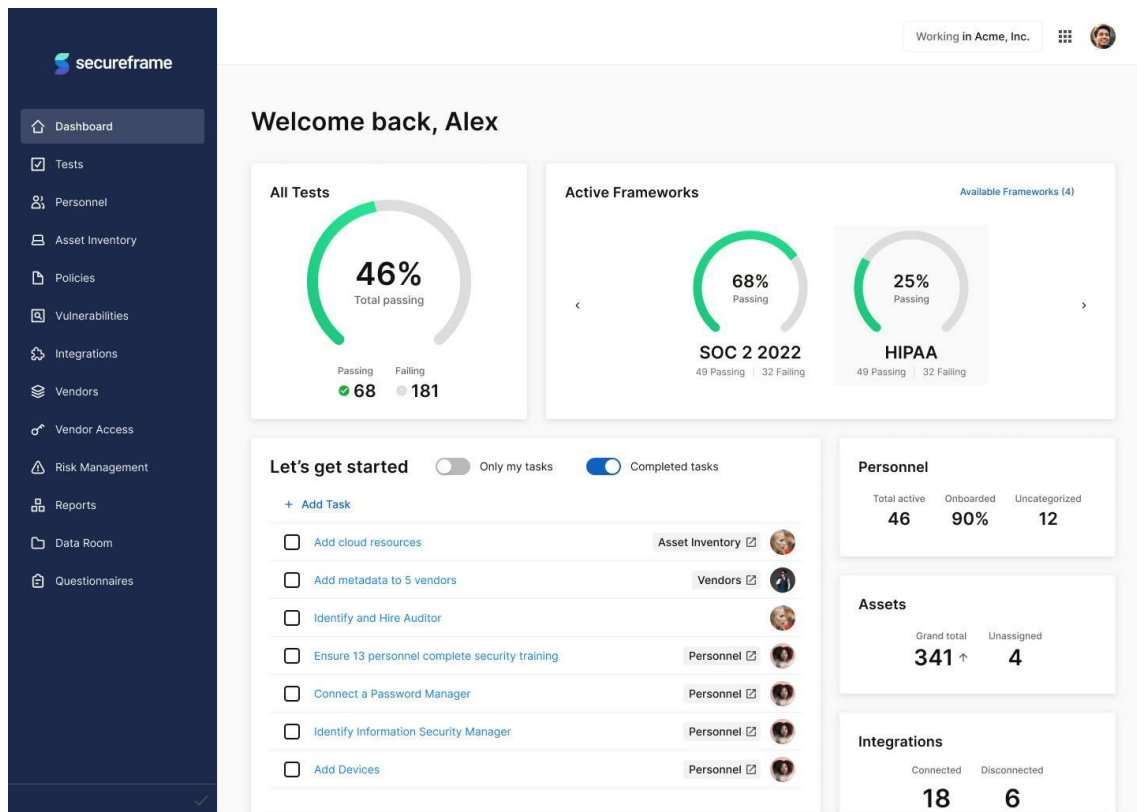


Figura 3 - Benchmarking 2

2.3.2 Análise de benchmarking

Características	ISMS.online	Vanta	Secureframe	Solução proposta
Suporte à ISO 27001	x	x	x	x
Gestão de utilizadores e permissões	x	x	x	x
Checklists de auditoria ISO 27001	x	x	x	x
Simulações/questionários educativos				x
Geração automática de xrelatórios	x	x	x	x
Dashboards de conformidade	x	x	x	x
Recomendações de ações corretivas	x	x	x	x
Foco educativo/aprendizagem				x
Baixa complexidade de utilização				x
Acessível a pequenas organizações				x
Integrações avançadas com sistemas externos	x	x	x	

2.4 Proposta de inovação e mais-valias

A solução proposta é inovadora por juntar, numa única plataforma online, ferramentas de apoio à auditoria ISO/IEC 27001 com conteúdos educativos. Ao contrário de muitas soluções existentes, que são complexas e caras, esta plataforma aposta na simplicidade e na facilidade de utilização, sendo especialmente indicada para utilizadores com pouca experiência na norma.

2.5 Identificação de oportunidade de negócio

Com vista a fomentar o empreendedorismo tecnológico, se for pertinente, sugere-se que se realize uma proposta de negócio para exploração comercial do projeto desenvolvido ou sucedâneos.

3 Especificação e Modelação

3.1 Análise de requisitos

User-Stories:

ID	User Story
US-01	Como gestor, quero criar e gerir utilizadores, para garantir que cada pessoa tem o acesso adequado à plataforma.
US-02	Como auditor, quero realizar auditorias baseadas na norma ISO 27001, para avaliar o nível de conformidade da organização.
US-03	Como auditor, quero registar o estado de conformidade de cada controlo avaliado.
US-04	Como auditor ou gestor, quero gerar e consultar relatórios de conformidade.
US-05	Como auditor ou gestor, quero visualizar indicadores de conformidade através de um dashboard.
US-06	Como utilizador, quero aceder a conteúdos educativos sobre a ISO 27001.

As user stories apresentadas encontram correspondência direta nos requisitos funcionais e nos casos de uso definidos nas secções seguintes, garantindo coerência e rastreabilidade entre as diferentes etapas da análise.

3.1.1 Requisitos Funcionais

Os requisitos funcionais descrevem as funcionalidades que a plataforma deverá disponibilizar aos seus utilizadores, considerando diferentes perfis de acesso e níveis de interação com o sistema.

ID	Descrição	Estado
req-01	O sistema deve permitir a adição de novos utilizadores, com diferentes perfis de acesso (auditor, gestor e utilizador comum).	Planeado
req-02	O sistema deve permitir a edição das permissões dos utilizadores.	Planeado
req-03	O sistema deve permitir a remoção de utilizadores.	Planeado
req-04	O sistema deve permitir iniciar questionários de auditoria baseados na norma ISO 27001.	Planeado
req-05	O sistema deve permitir responder às perguntas dos questionários com as opções “Em Conformidade” e “Não Conforme”.	Planeado
req-06	O sistema deve permitir a submissão e o armazenamento das respostas dos questionários de auditoria.	Planeado
req-07	O sistema deve permitir a geração de relatórios de conformidade com base nas respostas submetidas.	Planeado
req-08	O sistema deve permitir a visualização dos relatórios de conformidade.	Planeado
req-09	O sistema deve permitir a exportação dos relatórios de conformidade em formatos como PDF ou CSV.	Planeado
req-10	O sistema deve permitir a visualização de indicadores de conformidade através de um painel de controlo (dashboard).	Planeado
req-11	O sistema deve permitir a filtragem dos indicadores de conformidade por domínio ou controlo.	Planeado
req-12	O sistema deve permitir a exportação dos indicadores de conformidade.	Planeado
req-13	O sistema deve disponibilizar conteúdos educativos relacionados com a norma ISO 27001.	Planeado
req-14	O sistema deve apresentar exemplos práticos e ações corretivas associadas aos controlos da ISO 27001.	Planeado
req-15	O sistema deve permitir a exportação de conteúdos educativos.	Planeado
req-16	O sistema deve permitir o download de documentos educativos, como templates e exemplos de políticas.	Planeado
req-17	O sistema deve permitir a ativação de Autenticação Multi-Fator (MFA/2FA) via TOTP (ex: Google Authenticator).	Planeado

req-18	O sistema deve utilizar modelos de Inteligência Artificial para analisar não-conformidades e sugerir planos de ação.	Planeado
req-19	O sistema deve permitir a recolha de assinaturas digitais manuscritas para validação e fecho de auditorias.	Planeado
req-20	O sistema deve permitir o upload de evidências fotográficas ou documentos diretamente associados a cada controlo.	Planeado
req-21	O sistema deve incluir módulos de aprendizagem interativos com validação de conhecimentos (quizzes) e tracking de progresso.	Planeado

3.1.2 Requisitos Não Funcionais

Os Requisitos Não Funcionais (RNF) definem as restrições e os critérios de qualidade do sistema, focando-se em aspetos como a segurança, a conformidade legal, o desempenho e a usabilidade. Dada a natureza do projeto — manuseamento de dados de auditoria e segurança de informação —, estes requisitos assumem um carácter crítico.

Segurança e Conformidade

RNF-01 (Conformidade Legal): O sistema deve cumprir os requisitos impostos pelo Regulamento Geral sobre a Proteção de Dados (RGPD), garantindo especificamente o Direito ao Esquecimento (eliminação irreversível de conta), o Direito à Portabilidade (exportação de dados em formato de leitura automática) e o Dever de Informação.

RNF-02 (Controlo de Acesso e MFA): A plataforma deve mitigar riscos de usurpação de identidade, exigindo obrigatoriamente Autenticação Multifator (MFA/2FA) para acesso a dados sensíveis de auditoria.

RNF-03 (Confidencialidade de Credenciais): As palavras-passe dos utilizadores devem ser armazenadas utilizando algoritmos de cifragem forte e irreversível (com recurso a *hash* e *salt*), impedindo a sua leitura mesmo por administradores do sistema.

RNF-04 (Gestão de Sessões): O sistema deve utilizar mecanismos de autenticação baseados em *tokens* de curta duração, mitigando a janela de oportunidade para ataques de interceção de sessão.

RNF-05 (Defesa em Profundidade): O sistema deve garantir proteção nativa contra injeções de código malicioso (como SQL Injection e Cross-

Site Scripting) e bloquear proativamente o *upload* de extensões de ficheiros perigosos ou executáveis.

Desempenho e Disponibilidade

RNF-06 (Capacidade de Carga): A infraestrutura do sistema deve suportar, de forma estável, um mínimo de 20 a 50 utilizadores em simultâneo a realizar auditorias, sem degradação do serviço.

RNF-07 (Tempos de Resposta Base): O tempo de resposta para ações transacionais comuns, como *login*, submissão de respostas e navegação entre ecrãs, não deve exceder 2 segundos em condições normais de rede.

RNF-08 (Latência de Processamento IA): A geração de relatórios complexos com recurso a processamento de linguagem natural (Inteligência Artificial) deve ser concluída num tempo máximo de 15 segundos, devendo o sistema apresentar indicadores visuais de progresso ao utilizador durante a espera.

RNF-09 (Tolerância a Falhas): O sistema deve ser resiliente a falhas de comunicação com serviços externos. Em caso de indisponibilidade da API de Inteligência Artificial, a plataforma deve garantir como *fallback* a conclusão da auditoria, o cálculo matemático do *score* e a geração do PDF base.

Usabilidade e Acessibilidade

RNF-10 (Curva de Aprendizagem): Um utilizador com conhecimentos básicos de literacia digital deve conseguir iniciar e concluir a primeira secção de uma auditoria em menos de 5 minutos, sem necessidade de recorrer a manuais de instrução.

RNF-11 (Navegabilidade): A arquitetura de informação deve garantir que as ações fulcrais (iniciar auditoria, visualizar relatórios ou exportar dados pessoais) estejam acessíveis num máximo de 3 cliques a partir do painel principal.

RNF-12 (Responsividade): A interface de utilizador deve adotar uma abordagem *mobile-first*, garantindo total funcionalidade e adaptação a resoluções de ecrã a partir de 360px de largura.

RNF-13 (Compatibilidade Web): A plataforma deve operar corretamente nos motores de renderização mais recentes, sendo plenamente suportada por navegadores como Google Chrome, Mozilla Firefox, Safari e Microsoft Edge, sem a exigência de instalação de *plugins* adicionais.

3.1.3 Casos de Uso

UC-00 – Gerir Plataforma de Auditoria ISO 27001

Elemento	Descrição
Identificador	UC-00
Nome	Gerir Plataforma de Auditoria ISO 27001
Atores	Gestor, Auditor, Utilizador
Descrição	Representa o funcionamento global da plataforma, permitindo aos diferentes tipos de utilizadores interagir com o sistema para realizar auditorias, consultar resultados e aceder a recursos de apoio à norma ISO 27001.
Pré-condições	O utilizador encontra-se registado no sistema.
Pós-condições	As ações realizadas pelo utilizador ficam registadas no sistema para consulta futura.
Fluxo Principal	1. O utilizador acede à plataforma. 2. O utilizador interage com as funcionalidades disponíveis de acordo com o seu perfil. 3. O sistema disponibiliza funcionalidades de auditoria, análise e apoio à conformidade.
Observações	Caso de uso de alto nível que agrega todos os restantes casos de uso funcionais.

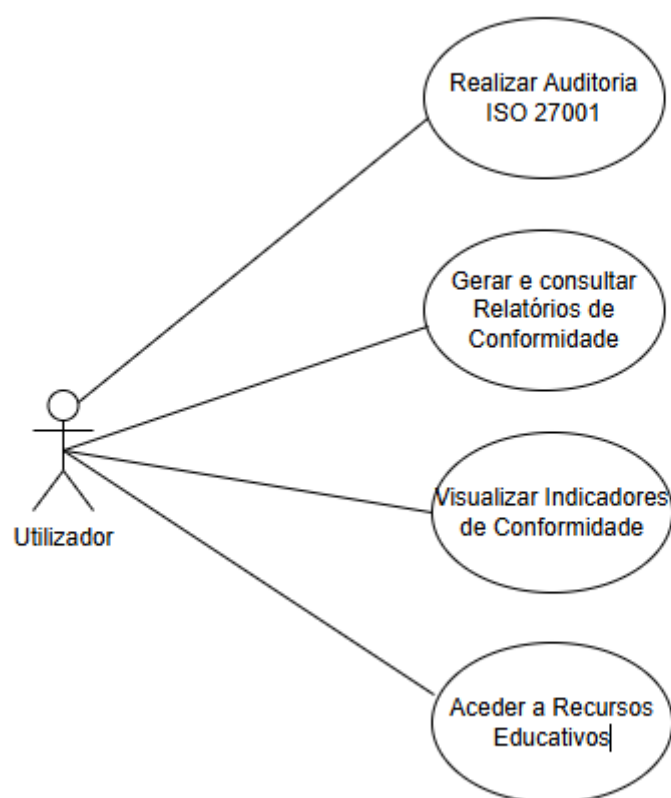


Figura 3 - Casos de uso

UC-01 – Gerir Utilizadores

Elemento	Descrição
Identificador	UC-01
Nome	Gerir Utilizadores
Atores	Gestor
Descrição	Permite ao gestor criar, editar ou remover utilizadores, definindo os respetivos perfis de acesso à plataforma.
Pré-condições	O gestor encontra-se autenticado no sistema.
Pós-condições	Os dados dos utilizadores ficam atualizados no sistema.
Fluxo Principal	1. O gestor acede à área de gestão de utilizadores. 2. O gestor cria, edita ou remove um utilizador. 3. O sistema guarda as alterações efetuadas.
Fluxos Alternativos	2a. O gestor cancela a operação sem efetuar alterações.

UC-02 – Realizar Auditoria ISO 27001

Elemento	Descrição
Identificador	UC-02
Nome	Realizar Auditoria ISO 27001
Atores	Auditor
Descrição	Permite ao auditor iniciar e responder a um questionário de auditoria baseado nos controlos da norma ISO 27001.
Pré-condições	O auditor encontra-se autenticado no sistema.
Pós-condições	As respostas da auditoria ficam registadas no sistema.
Fluxo Principal	1. O auditor inicia uma nova auditoria. 2. O sistema apresenta as questões baseadas na ISO 27001. 3. O auditor responde às questões. 4. O auditor submete a auditoria.
Fluxos Alternativos	3a. O auditor interrompe a auditoria e retoma mais tarde.

UC-03 – Gerar e Consultar Relatórios de Conformidade

Elemento	Descrição
Identificador	UC-03
Nome	Gerar e Consultar Relatórios de Conformidade
Atores	Auditor, Gestor
Descrição	Permite gerar relatórios de conformidade com base nas auditorias realizadas e consultar os respetivos resultados.
Pré-condições	Existe pelo menos uma auditoria submetida.
Pós-condições	O relatório de conformidade fica disponível para consulta.
Fluxo Principal	1. O utilizador seleciona uma auditoria. 2. O sistema gera o relatório de conformidade. 3. O utilizador visualiza o relatório.
Fluxos Alternativos	3a. O utilizador exporta o relatório para um ficheiro externo.

UC-04 – Visualizar Indicadores de Conformidade

Elemento	Descrição
Identificador	UC-04
Nome	Visualizar Indicadores de Conformidade
Atores	Auditor, Gestor
Descrição	Permite visualizar indicadores globais de conformidade através de um painel de controlo (dashboard).
Pré-condições	Existem auditorias registadas no sistema.
Pós-condições	Os indicadores são apresentados ao utilizador.
Fluxo Principal	1. O utilizador acede ao dashboard. 2. O sistema apresenta indicadores de conformidade.
Fluxos Alternativos	2a. O utilizador filtra os indicadores por domínio ou controlo.

UC-05 – Aceder a Recursos Educativos

Elemento	Descrição
Identificador	UC-05
Nome	Aceder a Recursos Educativos
Atores	Utilizador, Auditor
Descrição	Permite aceder a conteúdos educativos, exemplos práticos e documentos de apoio relacionados com a norma ISO 27001.
Pré-condições	O utilizador encontra-se autenticado.
Pós-condições	O utilizador consulta ou descarrega os recursos educativos.
Fluxo Principal	1. O utilizador acede à área de recursos educativos. 2. O sistema apresenta os conteúdos disponíveis. 3. O utilizador consulta ou descarrega os recursos.
Fluxos Alternativos	3a. O utilizador cancela a operação.

3.2 Modelação

Modelo Entidade-Relação

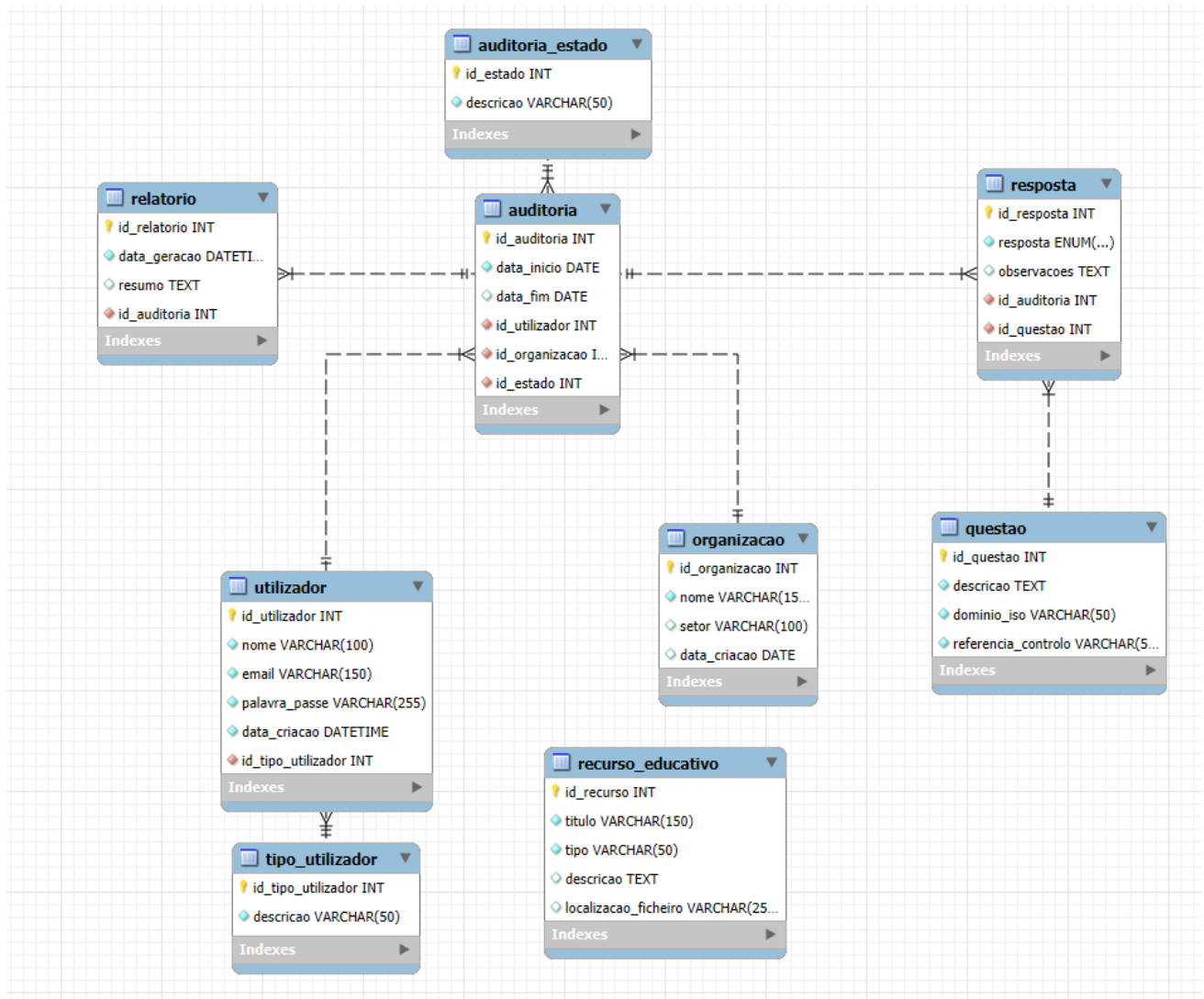


Figura 4 - Modelo Entidade-Relação

Entidades e Atributos

Tipo_Utilizador

Atributo	Tipo	Observações
id_tipo_utilizador	INT	Chave primária
descricao	VARCHAR(50)	Designação do tipo de utilizador (Gestor, Auditor, Utilizador)

Utilizador

Atributo	Tipo	Observações
id_utilizador	INT	Chave primária
nome	VARCHAR(50)	Nome do utilizador
email	VARCHAR(100)	Email único para autenticação
palavra_passe	VARCHAR(100)	Palavra-passe do utilizador
data_criacao	DATETIME	Data de criação do utilizador
id_tipo_utilizador	INT	Chave estrangeira → Tipo_Utilizador

Organização

Atributo	Tipo	Observações
id_organizacao	INT	Chave primária
nome	VARCHAR(100)	Nome da organização
setor	VARCHAR(50)	Setor de atividade
data_criacao	DATE	Data de registo da organização

Auditoria_Estado

Atributo	Tipo	Observações
id_estado	INT	Chave primária
descricao	VARCHAR(50)	Estado da auditoria (Em curso, Submetida, Concluída)

Auditoria

Atributo	Tipo	Observações
id_auditoria	INT	Chave primária
data_inicio	DATE	Data de início da auditoria
data_fim	DATE	Data de fim da auditoria
id_utilizador	INT	Chave estrangeira → Utilizador
id_organizacao	INT	Chave estrangeira → Organização
id_estado	INT	Chave estrangeira → Auditoria_Estado

Questão

Atributo	Tipo	Observações
id_questao	INT	Chave primária
descricao	TEXT	Texto da questão
dominio_iso	VARCHAR(50)	Domínio da ISO 27001
referencia_controlo	VARCHAR(50)	Referência ao controlo ISO 27001

Resposta

Atributo	Tipo	Observações
id_resposta	INT	Chave primária
resposta	ENUM	Valor da resposta (Em conformidade / Não conforme)
observacoes	TEXT	Observações do auditor
id_auditoria	INT	Chave estrangeira → Auditoria
id_questao	INT	Chave estrangeira → Questão

Relatório

Atributo	Tipo	Observações
id_relatorio	INT	Chave primária
data_geracao	DATETIME	Data de geração do relatório
resumo	TEXT	Resumo dos resultados
id_auditoria	INT	Chave estrangeira → Auditoria

Recurso_Educativo

Atributo	Tipo	Observações
id_recurso	INT	Chave primária
titulo	VARCHAR(100)	Título do recurso
tipo	VARCHAR(50)	Tipo de recurso educativo
descricao	TEXT	Descrição do conteúdo
localizacao_ficheiro	VARCHAR(100)	Localização do ficheiro

Relações entre Entidades

Entidade A	Entidade B	Tipo de Relação	Descrição
Tipo_Utilizador	Utilizador	1 : N	Um tipo de utilizador pode estar associado a vários utilizadores
Utilizador	Auditoria	1 : N	Um utilizador pode realizar várias auditorias
Organização	Auditoria	1 : N	Uma organização pode ter várias auditorias
Auditoria_Estado	Auditoria	1 : N	Um estado pode estar associado a várias auditorias
Auditoria	Resposta	1 : N	Uma auditoria possui várias respostas
Questão	Resposta	1 : N	Uma questão pode ter várias respostas
Auditoria	Relatório	1 : 1	Cada auditoria gera um único relatório
Recurso_Educativo	—	—	Entidade independente, sem relações diretas

3.3 Protótipos de Interface

Mapa aplicativo

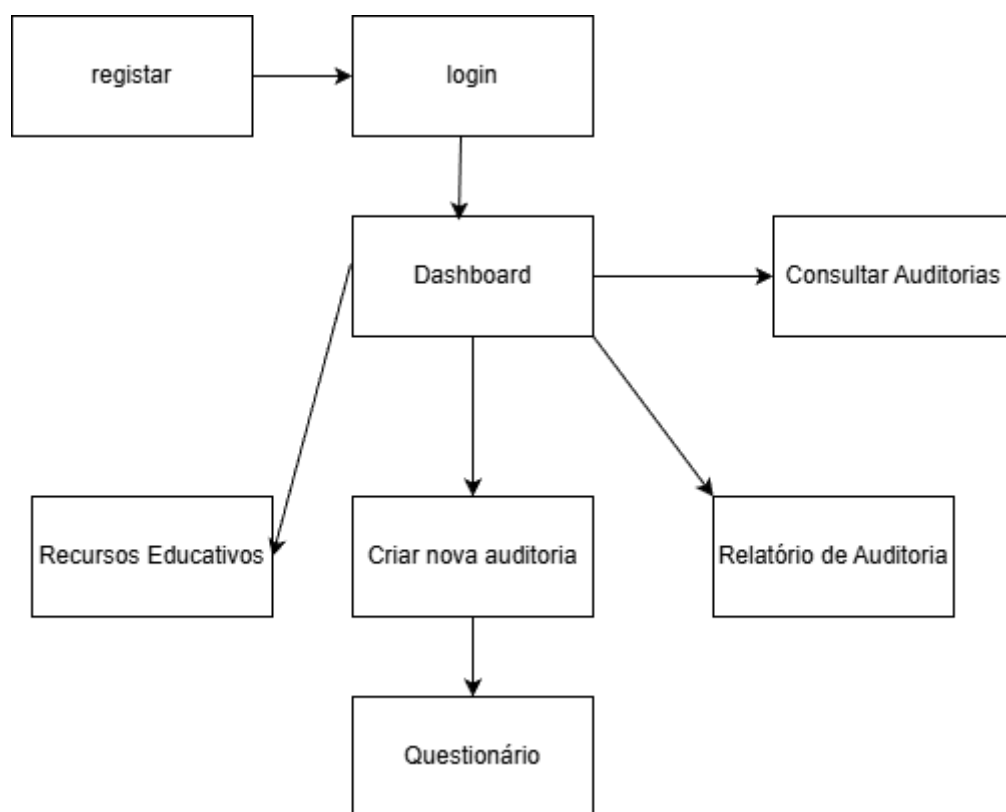


Figura 5 – Mapa aplicativo

4 Solução Desenvolvida

4.1 Introdução

A solução desenvolvida consiste numa plataforma web orientada à simplificação do ciclo de auditoria e conformidade com a norma ISO/IEC 27001:2022.

Funcionalmente, a aplicação permite a gestão de organizações, execução de checklists dinâmicas com recolha de evidências (anexos e notas), gestão de riscos e formação educativa. Comparativamente às soluções de benchmarking (como ISMS.online ou Vanta), a presente solução destaca-se pelo foco educativo e pela assistência direta na criação de planos de ação através de Inteligência Artificial, oferecendo uma interface menos complexa e mais acessível para PMEs.

Informações de Acesso:

- **Vídeo Demonstrativo:** [[Link do YouTube](#)]
- **Repositório Git:** [[Link do GitHub](#)]
- **Solução Funcional:** [[URL da Render](#)]

Este capítulo descreve a arquitetura do sistema (4.2), as tecnologias e ferramentas utilizadas (4.3), os ambientes de produção (4.4), a abrangência curricular (4.5), o detalhe técnico dos componentes (4.6) e o mapa de interfaces (4.7).

4.2 Arquitetura

A arquitetura baseia-se num modelo Cliente-Servidor estritamente desacoplado. O Frontend (React) gere a interface e o estado da aplicação, comunicando via REST API com o Backend (Django). Esta opção garante a modularidade: o servidor de dados pode ser escalado independentemente da interface. A lógica de negócio está centralizada no Backend, protegendo a integridade dos dados e garantindo que o processamento pesado (como a análise de IA e geração de relatórios) não impacta a performance do browser do utilizador.

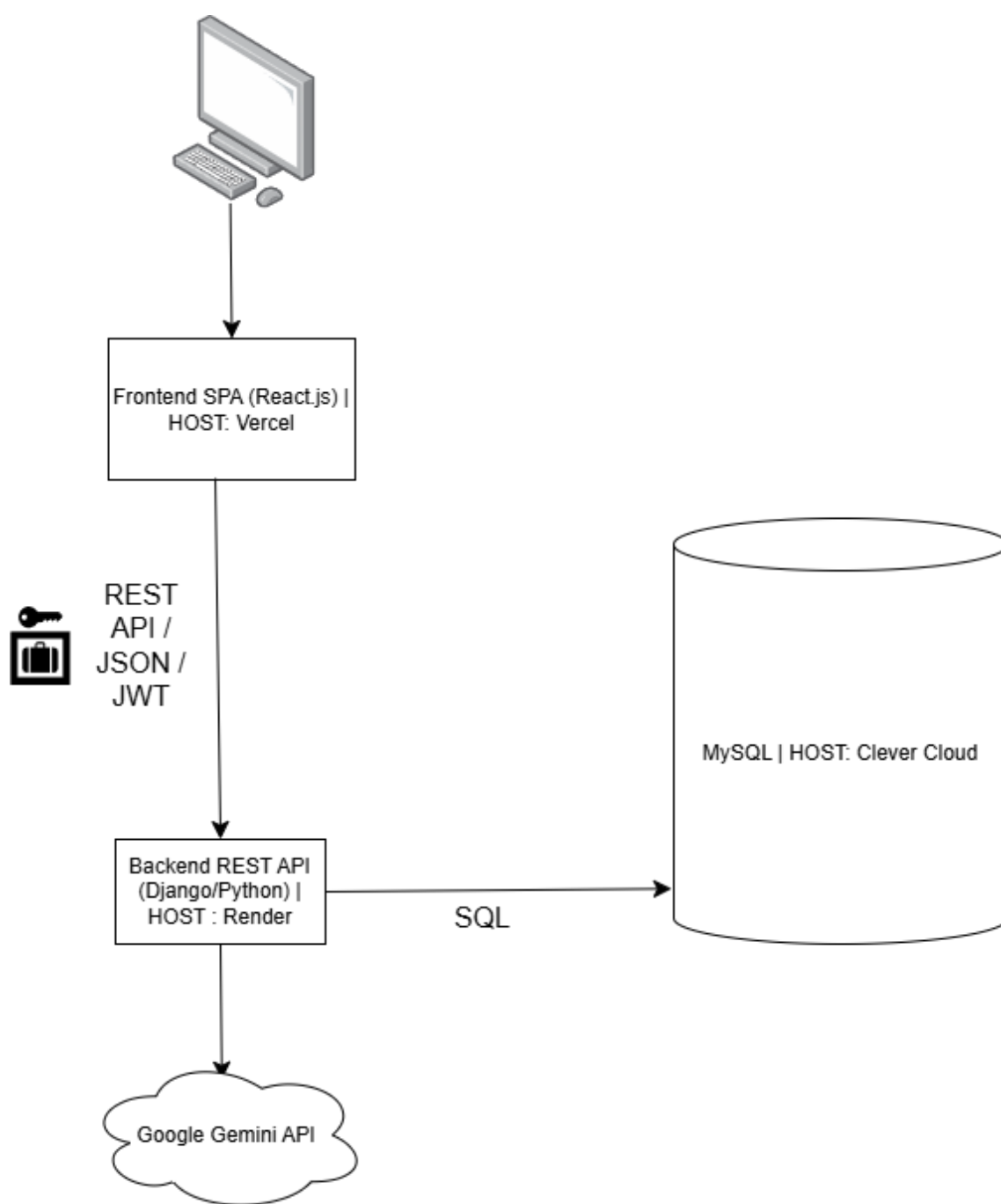


Figura 6 - Diagrama da arquitetura Cliente-Servidor e integração de componentes

4.3 Tecnologias e Ferramentas Utilizadas

A seleção tecnológica para a construção da plataforma teve como prioridade a escalabilidade, a segurança dos dados e a rapidez de desenvolvimento de uma Single Page Application (SPA).

Frontend (Camada de Apresentação):

- **React.js:** Escolhido pela sua arquitetura baseada em componentes reutilizáveis, permitindo uma navegação fluida sem recarregamento da página (através da biblioteca react-router-dom).
- **Axios:** Cliente HTTP baseado em Promises, utilizado para garantir uma comunicação assíncrona e eficiente com a REST API.
- **React-Signature-Canvas:** Biblioteca especializada introduzida para dar resposta ao requisito de recolha de assinaturas digitais nos relatórios de auditoria, convertendo o input num formato Base64.

Backend (Camada de Lógica de Negócio):

- **Python 3 & Django:** Framework de alto nível escolhida pela sua robustez nativa contra vulnerabilidades comuns (ex: SQL Injection, Cross-Site Scripting) e pelo seu sistema de ORM (Object-Relational Mapping) eficiente.
- **Django REST Framework (DRF):** Utilizado para a serialização rápida de modelos complexos de base de dados em formatos JSON.
- **Djangorestframework-simplejwt & PyOTP:** Bibliotecas cruciais para a implementação de segurança avançada. O SimpleJWT garante sessões seguras e stateless, enquanto o PyOTP suporta a Autenticação Multi-Fator (2FA) baseada no tempo.
- **Google-generativeai:** SDK oficial utilizado para integrar as funcionalidades preditivas e gerativas do LLM Google Gemini.

Base de Dados e Infraestrutura:

- **MySQL 8.0:** Sistema de Gestão de Bases de Dados Relacional. A escolha de uma base de dados relacional foi imperativa para manter a forte integridade referencial entre as normas ISO, os controlos, as auditorias e os planos de ação.
- **Git & GitHub:** Utilizados para o controlo de versões, garantindo um histórico seguro de todo o código fonte e facilitando o processo de deploy contínuo.

4.4 Ambientes de Teste e de Produção

O ciclo de vida da solução desenvolvida foi suportado por dois ambientes distintos, permitindo separar a fase de desenvolvimento e testes unitários da fase de exploração real em ambiente Cloud.

4.4.1 Ambiente de Teste (Desenvolvimento Local)

Para o desenvolvimento e testes de integração, utilizou-se um ambiente local controlado, simulando a arquitetura final.

- **Recursos Computacionais:** Estação de trabalho com processador de arquitetura x86 (2.4 GHz) e 8 GB de memória RAM, assegurando a execução fluida do servidor de desenvolvimento React e do servidor WSGI do Django.
- **Armazenamento:** Alocação de aproximadamente 1.5 GB de armazenamento em disco para o código-fonte, bibliotecas virtuais e logs de execução.
- **Rede:** Comunicação em *localhost* via protocolo HTTP nas portas 3000 (Frontend) e 8000 (Backend).

4.4.2 Ambiente de Produção (Exploração)

A exploração produtiva da solução é realizada numa infraestrutura Cloud distribuída (PaaS e SaaS), cujos recursos foram dimensionados de acordo com as especificações técnicas dos fornecedores utilizados:

- **Camada de Lógica (Backend - Render):**
 - o **Recursos Computacionais:** Instância baseada em contentores Linux com **512 MB de memória RAM** e **0.1 vCPU** (recursos do escalão Web Service). Estes valores são suficientes para o processamento de pedidos REST e gestão de JWT.
 - o **Rede:** Interface de rede com débito nominal de **100 Mbps** e limite de largura de banda (*egress*) de **100 GB mensais**, garantindo baixa latência na comunicação externa.
- **Camada de Persistência (Base de Dados - Clever Cloud):**
 - o **Armazenamento:** Instância de MySQL 8.0 com quota fixa de **500 MB** de armazenamento em disco, valor recomendado para suportar milhares de registos textuais de auditoria.
 - o **Rede:** Suporte para 5 ligações (conexões) simultâneas, assegurando a integridade das transações do SGBD.

- Camada de Apresentação (Frontend - Vercel):

- **Recursos e Rede:** Rede de distribuição de conteúdos (CDN) global *serverless*, suportando um tráfego de largura de banda de até **100 GB mensais** e execução de funções com limite de timeout de **10 segundos** (escalonamento Hobby).

- Serviços de Terceiros (Web Services - Google Gemini):

- **Recursos de Processamento:** Serviço de Inteligência Artificial consumido via REST API (HTTPS). A exploração está limitada pela quota do escalão gratuito, suportando até **15 pedidos por minuto (RPM)**, **1 milhão de tokens por minuto (TPM)** e um máximo de **1.500 pedidos diários (RPD)**.

4.5 Abrangência

O desenvolvimento desta solução mobilizou conhecimentos transversais adquiridos ao longo do curso, integrando diversas áreas científicas da engenharia informática. A seguir, detalham-se as principais Unidades Curriculares (UC) aplicadas e a forma como os conhecimentos nelas adquiridos foram materializados no projeto:

Programação para a Web: Os conceitos fundamentais de arquitetura Cliente-Servidor e o ciclo de vida de pedidos HTTP, explorados através de Java Servlets e conectividade JDBC com MySQL, serviram de base teórica essencial. Este conhecimento sólido de *backend* e encaminhamento de dados permitiu uma transição estruturada e autónoma para a implementação da solução final utilizando *frameworks* mais modernas, substituindo os Servlets por uma API em Django e o *frontend* tradicional por uma SPA em React.

Bases de Dados: O conhecimento em sistemas relacionais foi aplicado no desenho, normalização e implementação do esquema de dados no SGBD MySQL, estruturando as relações entre organizações, controlos da norma (Anexo A), evidências submetidas e utilizadores.

Programação de Sistemas Inteligentes: Os conceitos lecionados nesta disciplina foram utilizados na integração de ferramentas de Inteligência Artificial, nomeadamente na comunicação com a API do Google Gemini para o processamento de linguagem natural e a geração automatizada de Planos de Ação Corretiva.

Engenharia de Software & Análise e Desenho de Sistemas: As metodologias destas UCs foram aplicadas no levantamento exaustivo de requisitos funcionais e não-funcionais, na modelação de casos de uso (UML) e na definição de uma arquitetura de sistema modular.

Interação Homem-Máquina & Desenho de Sistemas Interativos: Os princípios de ergonomia e usabilidade serviram de base para o planeamento e *design* da interface gráfica (UI/UX), refletindo-se na navegação intuitiva dos *dashboards* analíticos e na fluidez de preenchimento das *checklists*.

Redes de Computadores: O conhecimento sobre protocolos de comunicação (HTTP/HTTPS) e portas de rede foi aplicado na configuração das ligações seguras entre o Frontend, o Backend e a Base de Dados externa, assegurando o tráfego de pedidos REST e a gestão de *tokens* (JWT).

Gestão de Projetos: As práticas abordadas foram aplicadas no planeamento do tempo, na definição de metas (*milestones* para o Projeto I e Projeto II) e na gestão iterativa das tarefas de desenvolvimento.

4.6 Componentes

A plataforma divide-se em cinco grandes componentes funcionais que interagem de forma síncrona para garantir a integridade do processo de auditoria:

4.6.1 Componente 1: Motor de Auditoria e Checklist Dinâmica

Este é o módulo central da aplicação, responsável pela recolha de dados primários e verificação de conformidade.

- **Implementação e Lógica:** Permite iniciar uma auditoria associada a uma entidade específica, com identificação de metadados e captura de assinaturadigital (através do componente react-signature-canvas).
- **Dinamismo:** A checklist é gerada dinamicamente com base nos domínios da norma ISO/IEC 27001:2022 (controlos A.5 a A.8).
- **Barra de Ações Rápidas:** Incorporada em cada pergunta, permite ao auditor responder (Sim/Não/NA). No caso de resposta negativa, o sistema aciona automaticamente alertas visuais de "Não Conformidade" e obriga à justificação no campo de "Notas".
- **Gestão de Evidências:** Permite o upload de ficheiros de prova, cujos dados são encapsulados em objetos FormData e enviados para a API, onde são associados ao registo da auditoria na base de dados.

4.6.2 Componente 2: Gestão de Riscos e Ações Corretivas

Sempre que uma falha é detetada no motor de auditoria, os dados alimentam automaticamente o módulo de Riscos.

- **Visualização Interativa:** Os riscos são apresentados num formato de cartões interativos (estilo Kanban), permitindo uma gestão visual do estado de tratamento de cada vulnerabilidade.
- **Classificação Dinâmica:** Utiliza *badges* coloridos que refletem a gravidade do risco (ex: Crítico em vermelho escuro) e a referência direta ao controlo da norma (ex: A.8.13).
- **Ciclo PDCA:** O auditor pode, a partir desta interface, converter um risco num plano de "Ação Corretiva", definindo responsáveis, prazos de resolução e estados de execução (*To Do, In Progress, Done*).

4.6.3 Componente 3: Painel de Controlo (Dashboard) e Perfis de Auditor

Este componente centraliza a inteligência de negócio e a gestão de identidade profissional.

- **Métricas em Tempo Real:** O Dashboard consome dados da API para gerar métricas de conformidade, tais como a Taxa de Conformidade Média, volume de auditorias ativas e densidade de riscos por domínio.
- **Identidade e Validade:** O módulo de Perfil do Auditor permite o registo de credenciais profissionais (ex: N.º de Registo IRCA) e o upload de certificados em formato PDF. Esta funcionalidade confere validade formal aos relatórios finais, garantindo que o autor da auditoria possui as competências necessárias.

4.6.4 Componente 4: Biblioteca e Recursos Educativos (Awareness)

Desenvolvido para responder ao requisito da norma que exige a sensibilização e formação dos colaboradores em segurança da informação.

- **Repositório de Conhecimento:** Funciona como um Sistema de Gestão de Aprendizagem (LMS) simplificado, onde são disponibilizados módulos de formação e boas práticas de segurança.
- **Monitorização de Progresso:** O sistema regista a interação dos utilizadores com os materiais educativos, gerando evidências automáticas de que a organização está a cumprir o plano de formação contínua exigido pela ISO 27001.

4.6.5 Componente 5: Inteligência Artificial (Análise Prescritiva)

Este componente atua como um consultor virtual integrado, elevando a plataforma de uma ferramenta de registo para uma ferramenta de decisão.

- **Integração Gemini API:** Utiliza o modelo de linguagem *Gemini 1.5 Flash* para analisar as não-conformidades submetidas.
- **Geração de Planos:** Com base no contexto da falha detetada e nas notas do auditor, a IA gera automaticamente sugestões técnicas e planos de ação detalhados. Isto reduz drasticamente o tempo de consultoria manual e garante que as correções propostas estão alinhadas com as melhores práticas internacionais de segurança.
- **Processamento:** A lógica é executada no *backend* (Django), garantindo que os dados são filtrados e sanitizados antes de serem enviados para o modelo de IA, assegurando a privacidade da informação.

4.7 Interfaces

Nesta secção apresenta-se o mapa aplicacional através dos ecrãs mais representativos da solução. A interface foi desenhada com foco na sobriedade e eficiência, utilizando uma paleta de cores profissional e uma disposição de elementos que minimiza o número de cliques necessários para completar uma auditoria.

4.7.1 Autenticação e Segurança (Login & 2FA)

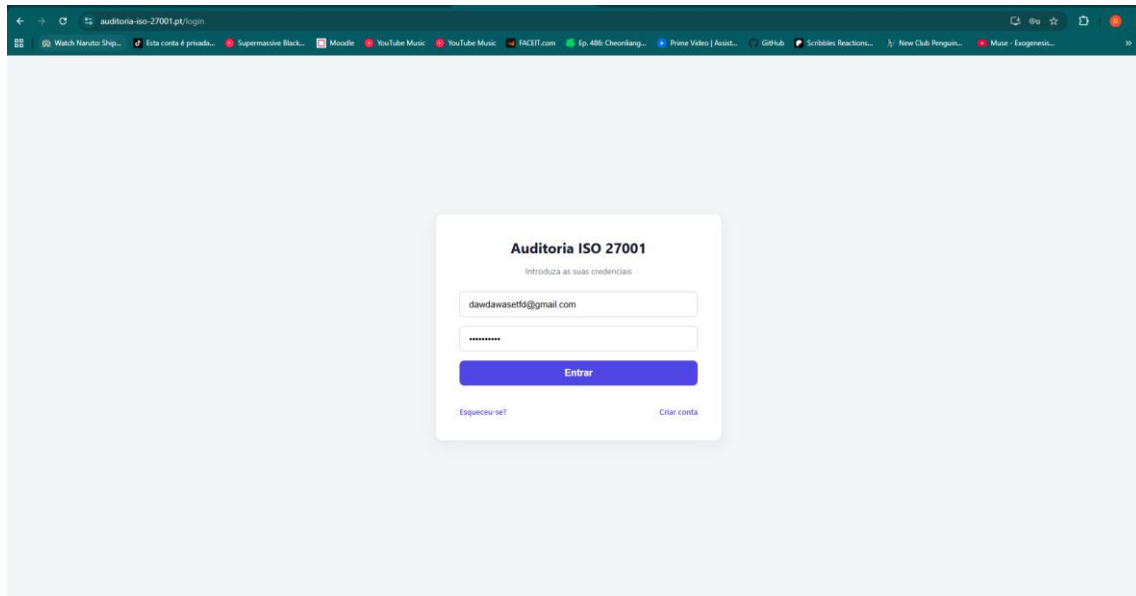


Figura 7 – Login



Figura 8 - MFA

— Funcionalidade: Este é o ponto de entrada da aplicação, desenhado para validar a identidade do utilizador através de um sistema de duas etapas. O fluxo principal garante a autenticação base por email e palavra-passe, suportando condicionalmente a exigência de um segundo fator de autenticação (MFA) caso o auditor o tenha ativado no seu perfil.

— Implementação: Desenvolvido em React com formulários controlados, o componente Loginn.js inicia a comunicação fazendo um pedido HTTP POST ao *endpoint* /api/login-step-1/. No lado do servidor, o Django valida as credenciais primárias e verifica a flag *dois_fatores_ativo* do perfil do utilizador. Caso seja necessário o segundo fator, a interface adapta-se dinamicamente para capturar o código de 6 dígitos, enviando-o para o *endpoint* /api/login-step-2-verify/, onde a biblioteca PyOTP valida o *Time-based One-Time Password* (TOTP) face ao segredo armazenado na base de dados.

— Decisões de Implementação: Optou-se por um *design* minimalista e por um fluxo de autenticação segmentado em dois *endpoints* distintos. Esta decisão arquitetural permite que a plataforma suporte utilizadores com diferentes níveis de segurança sem quebrar a experiência de utilização. A integração de TOTP reflete diretamente a adoção do controlo A.5.17 (Informação de autenticação) da norma ISO/IEC 27001.

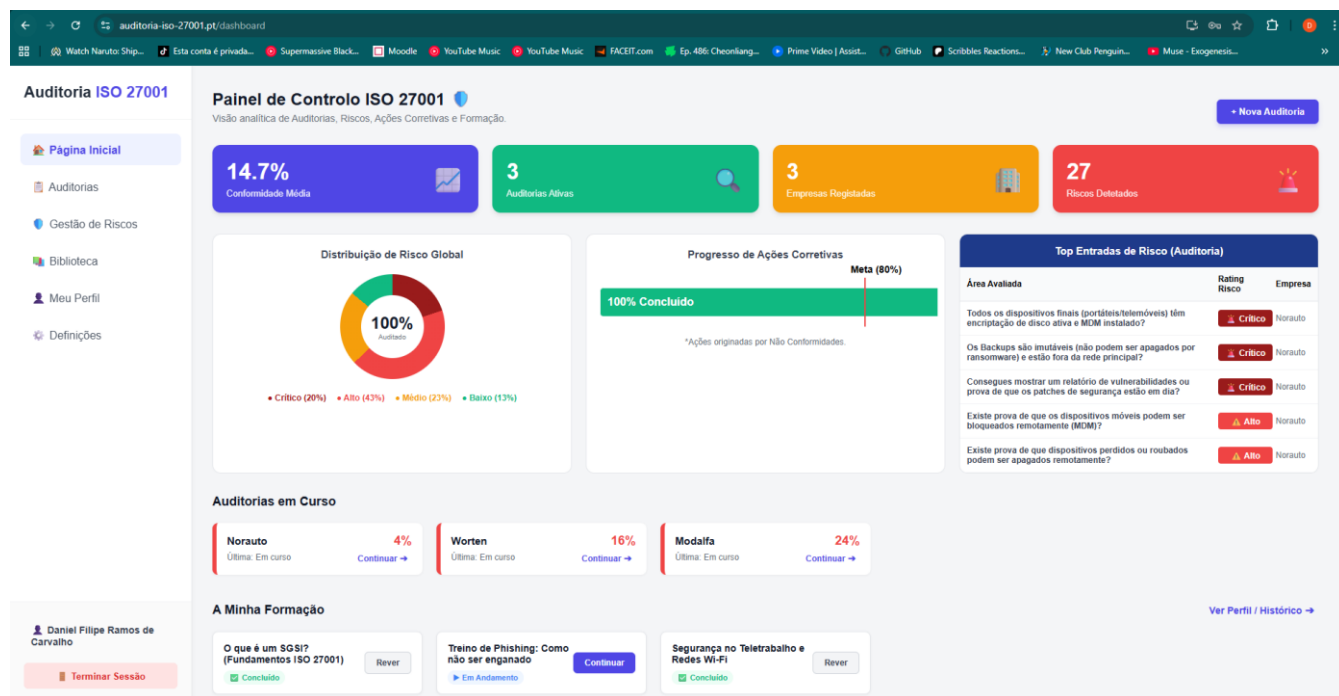


Figura 9 – Dashboard com indicadores de conformidade e estados das formações

4.7.2 Gestão de Auditorias

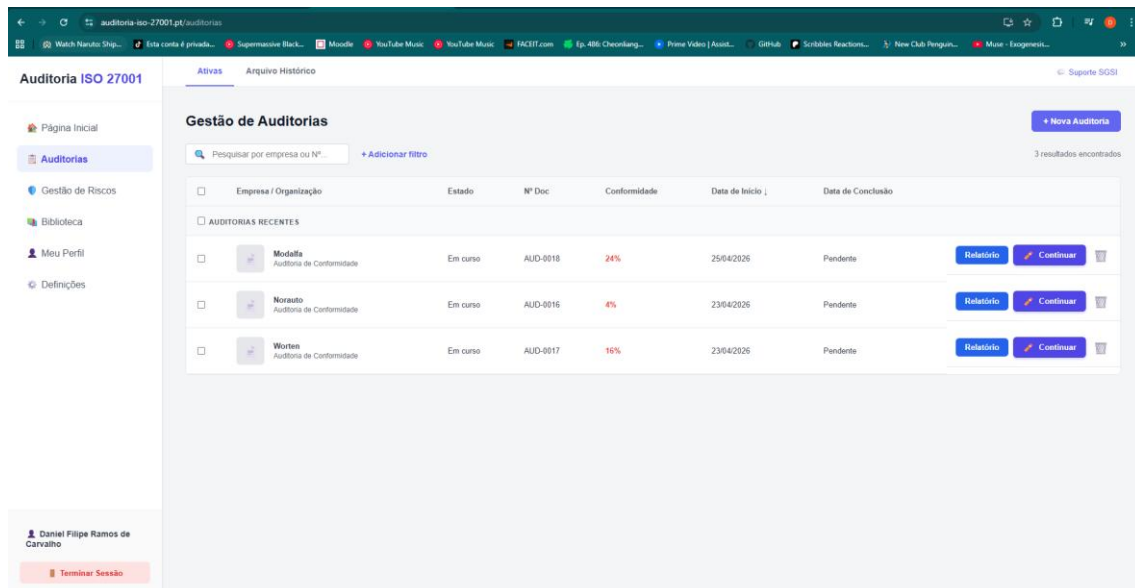


Figura 10 – Página de Gestão de Auditorias

— Funcionalidade: Este ecrã atua como o centro de operações para o histórico e acompanhamento de auditorias. Permite ao utilizador visualizar rapidamente o estado de cada avaliação, retomar auditorias pendentes, eliminar registos ou gerar o relatório final de conformidade.

— Implementação: O componente Auditorias.js consome o *endpoint* `/api/auditorias-tabela/`, gerido pelo Django. A tabela é renderizada dinamicamente em React, iterando sobre o *array* de dados recebido. Foram implementados mecanismos de proteção no *frontend*, como caixas de diálogo de confirmação (`window.confirm`) antes de invocar o método HTTP DELETE, garantindo que a eliminação em cascata de respostas e ficheiros na base de dados não ocorre por acidente.

— Decisões de Implementação: Optou-se por uma interface tabular *clean* com codificação de cores intuitiva (ex: *badges* verdes para "Concluído" ou pontuações altas, vermelhos para "Em curso" ou pontuações baixas). A disponibilização de ações rápidas diretamente na linha da tabela minimiza o número de cliques, otimizando o fluxo de trabalho do auditor.

4.7.3 Geração de Relatório Inteligente (PDF e IA)



Conduzido em	25/04/2026
Concluído em	Pendente
Norma de Referência	ISO/IEC 27001:2022
Estado da Auditoria	Em curso
Resultado Global	24%

Plano de Ação Corretiva

ISO	Falha Detetada	Solução Recomendada
[A.6.1] É feita uma verificação de antecedentes (background check, referências) adequada ao nível de risco antes de cada contratação?	Ausência de um processo formal e consistente de verificação de antecedentes e referências, adequado ao nível de risco da função, antes da contratação de novos colaboradores.	Desenvolver e implementar um procedimento padronizado para a realização de background checks e verificação de referências, definindo os critérios e a profundidade da verificação com base no nível de risco e responsabilidade da posição, antes de cada nova contratação.
[A.6.2] As responsabilidades de segurança constam nos contratos de trabalho dos colaboradores?	As responsabilidades específicas de segurança da informação não estão formalmente documentadas e incluídas nos contratos de trabalho ou em documentos de funções equivalentes.	Rever e atualizar os modelos de contrato de trabalho para incluir cláusulas claras e detalhadas sobre as responsabilidades de segurança da informação para cada função, garantindo que os colaboradores reconheçam e compreendam as suas obrigações.
[A.6.3] Consegues mostrar os certificados ou registos de presença da última formação de segurança?	Não existem registos formais e auditáveis (certificados, listas de presença) que comprovem a participação dos colaboradores em formações de segurança da informação.	Implementar um sistema de gestão de formação que registre a participação e a conclusão de todas as formações de segurança da informação, assegurando a retenção de evidências documentais (e.g., certificados, listas de presença, resultados de testes).
[A.6.3] É realizado algum teste de Phishing simulado para medir a consciencialização?	A organização não realiza testes de phishing simulados regularmente para avaliar a eficácia das formações de consciencialização e a resiliência dos colaboradores a ataques de engenharia social.	Desenvolver e implementar um programa contínuo de testes de phishing simulados, com periodicidade definida. Após cada teste, fornecer feedback construtivo e formações adicionais direcionadas para os colaboradores que necessitem de reforço.
[A.6.4] Existe um processo disciplinar formal para violações de segurança da informação?	Inexistência de um processo disciplinar formal, documentado e comunicado, para lidar com violações das políticas de segurança da informação.	Elaborar e implementar um procedimento disciplinar claro e formal para violações de segurança da informação, definindo as etapas, as responsabilidades e as possíveis sanções, e garantir que este seja amplamente comunicado a todos os colaboradores.
[A.6.5] Os colaboradores que rescindem contrato são lembrados formalmente de que os Acordos de Confidencialidade (NDA) continuam válidos?	O processo de desvinculação de colaboradores não inclui um lembrete formal e documentado da continuidade das obrigações de confidencialidade (NDAs), aumentando o risco de fuga de informação pós-emprego.	Integrar no processo de offboarding (desvinculação) um passo obrigatório para reforçar formalmente (por escrito e com registo de confirmação) a validade e as implicações dos Acordos de Confidencialidade (NDAs) após a cessação do contrato de trabalho.
[A.6.6] Todos os colaboradores e prestadores de serviços assinaram acordos de confidencialidade (NDA)?	Nem todos os colaboradores e prestadores de serviços que têm acesso a informações sensíveis assinaram um Acordo de Confidencialidade (NDA) válido.	Auditar e garantir que todos os colaboradores e prestadores de serviços com acesso a informação confidencial possuem um NDA válido e assinado. Implementar um controlo rigoroso para que esta seja uma condição prévia a qualquer acesso a informação para futuras contratações/colaborações.
[A.6.7] Os equipamentos usados em teletrabalho têm as mesmas proteções que os do escritório?	Os equipamentos utilizados pelos colaboradores em teletrabalho não possuem o mesmo nível de proteção e controlo de segurança que os equipamentos no escritório, criando potenciais vulnerabilidades.	Desenvolver e implementar uma política de segurança para teletrabalho, garantindo que os equipamentos e as ligações de rede utilizadas remotamente estão sujeitos às mesmas medidas de segurança (e.g., antivírus, firewall, VPN, atualizações, autenticação robusta) que os equipamentos e redes internas.

Figura 12 - Relatório de conformidade inteligente com análise prescritiva da IA 2

Controlo Avaliado	Evidência	Resultado
Existe prova de que os dispositivos móveis podem ser bloqueados remotamente (MDM)?	-	SIM
Todos os dispositivos finais (portáteis/telemóveis) têm encriptação de disco ativa e MDM instalado?	-	SIM
Existe prova de que dispositivos perdidos ou roubados podem ser apagados remotamente?	-	SIM
Existe prova de que a informação é eliminada de forma segura quando o tempo de retenção termina?	-	SIM
Os dados de produção (clientes reais) são usados em ambientes de teste sem serem mascarados?	-	SIM
Dados sensíveis de clientes são mascarados ou anonimizados em relatórios ou ambientes não produtivos?	-	SIM

Validação e Assinatura do Auditor:

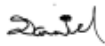


Figura 13 – Relatório de conformidade inteligente com análise prescritiva da IA 3

— Funcionalidade: Representa o *output* final da plataforma. Transforma as dezenas de respostas e notas recolhidas durante a auditoria num documento executivo em formato PDF, enriquecido com gráficos visuais e uma análise prescritiva gerada por Inteligência Artificial.

— Implementação: Esta funcionalidade apresenta uma arquitetura híbrida. Quando o botão "Relatório" é acionado, o React faz um pedido ao *backend* (`/api/auditoria/{id}/pdf-dados/`). O Django processa a matemática da conformidade (excluindo respostas "N/A" da equação), gera um gráfico circular com a biblioteca *matplotlib* (enviado em formato Base64) e compila as falhas detetadas num *prompt*. Este *prompt* é processado pelo modelo Gemini 2.5 Flash (com sistema de *fallback* para OpenAI), que devolve um JSON estruturado com o resumo executivo e o plano de ação. Por fim, o *frontend* utiliza as bibliotecas *jsPDF* e *jspdf-autotable* para desenhar e exportar o documento diretamente no *browser* do utilizador.

— Decisões de Implementação: A decisão de desenhar o PDF no lado do cliente (*client-side rendering* com *jsPDF*) reduz drasticamente a carga de processamento no servidor (Render). A injeção de IA na fase final converte uma simples ferramenta de registo (checklist) num assistente de consultoria, gerando valor acrescentado imediato para a organização auditada ao entregar propostas concretas de mitigação de risco.



— **Funcionalidade:** Este componente é responsável por transformar as não-conformidades detetadas durante a fase de auditoria em itens de gestão ativos. Permite ao utilizador visualizar as falhas, atribuir responsáveis e prazos (Plano de Ação), e encerrar os riscos mediante a submissão de evidências de resolução.

— Implementação e Gatilhos: O sistema utiliza um gatilho (Signal) no Django que monitoriza a tabela de respostas. Sempre que uma resposta é gravada como "Não", o servidor cria automaticamente um registo na tabela de Riscos, herdando o nível de risco sugerido e a referência da norma (ex: A.8.13). No *frontend*, o componente Riscos.js consome o *endpoint* /api/riscos-lista/ e apresenta os dados organizados por estados através de filtros dinâmicos: Pendentes, Em Curso e Resolvidos.

— Fluxo de Tratamento: A interface disponibiliza modais interativos para a gestão do ciclo de vida do risco. Ao "Tratar Risco", o utilizador define um responsável e um prazo, o que altera o estado para "Em Curso" via pedido POST. Para "Marcar como Feito", o sistema exige o *upload* de um ficheiro de evidência de resolução; uma vez submetido, o Django atualiza não só o estado do risco para "Resolvido", mas também retroalimenta a resposta original da auditoria, alterando-a para "Sim" e anexando a prova da correção.

— Decisões de Implementação: Optou-se por uma visualização baseada em cartões com identificadores visuais de criticidade (cores que variam entre o vermelho escuro para riscos "Críticos" e o verde para "Baixos"), facilitando a priorização por parte do gestor de segurança. A decisão de automatizar a criação do risco a partir da auditoria garante que nenhuma falha identificada se perde por erro humano, assegurando o cumprimento integral do ciclo de melhoria contínua (PDCA) exigido pela ISO 27001.

4.7.6 Biblioteca de Recursos e Formação (Awareness)

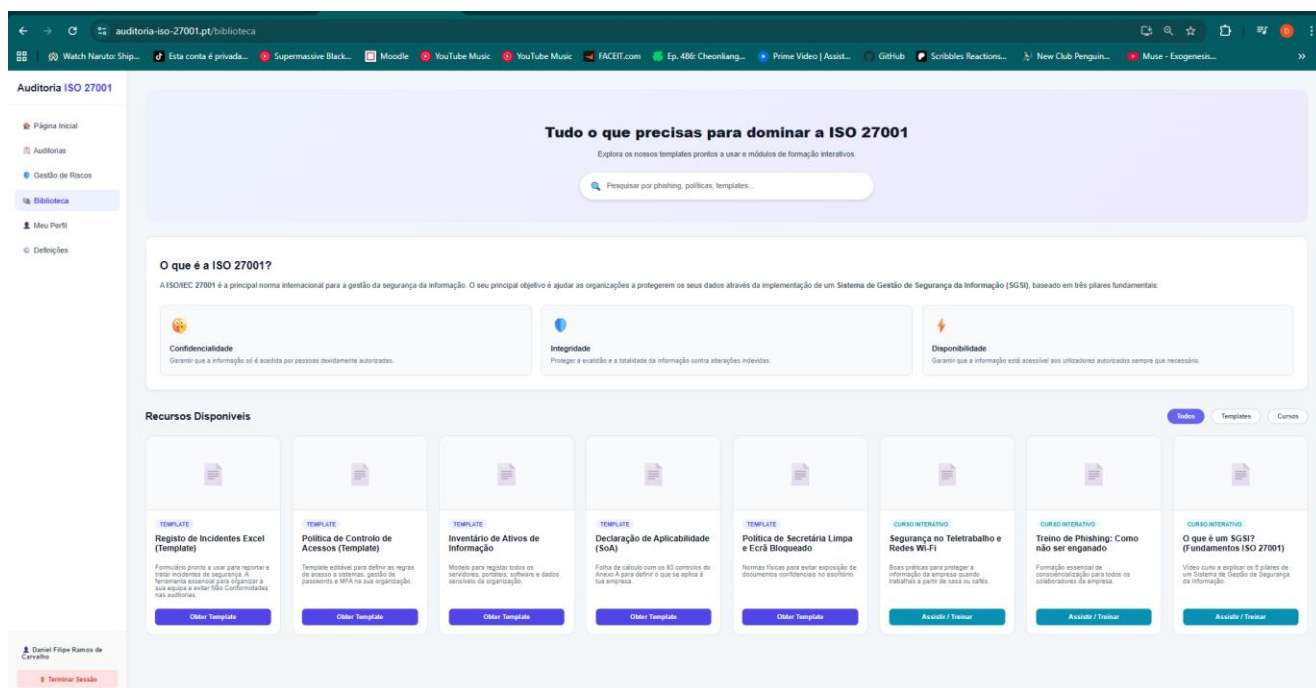


Figura 16 – Página da Biblioteca / Recursos e Cursos

— Funcionalidade: Este módulo serve como o centro de conhecimento e sensibilização da plataforma. Permite aos utilizadores aceder a materiais de formação, manuais de boas práticas e templates de auditoria, organizados por categorias como "Cibersegurança" ou "Normas ISO".

— Implementação: O componente Biblioteca.js consome o *endpoint* `/api/recursos-educativos/` através de um pedido GET assíncrono. A interface implementa uma lógica de filtragem local em React, permitindo que o utilizador alterne entre categorias sem novos pedidos ao servidor. Caso o recurso seja um curso interativo, o sistema redireciona o utilizador para o `CursoPlayer.js`, passando o ID do curso via parâmetros de rota.

— Decisões de Implementação: Optou-se por uma disposição em grelha (*grid*) com cartões visuais para tornar a aprendizagem menos monótona. A inclusão de uma barra de pesquisa dinâmica visa facilitar o acesso rápido a documentos específicos, cumprindo o requisito da norma ISO 27001 relativo à disponibilização e controlo de informação documentada e consciencialização dos colaboradores.

4.7.7 Perfil do Utilizador e Qualificações

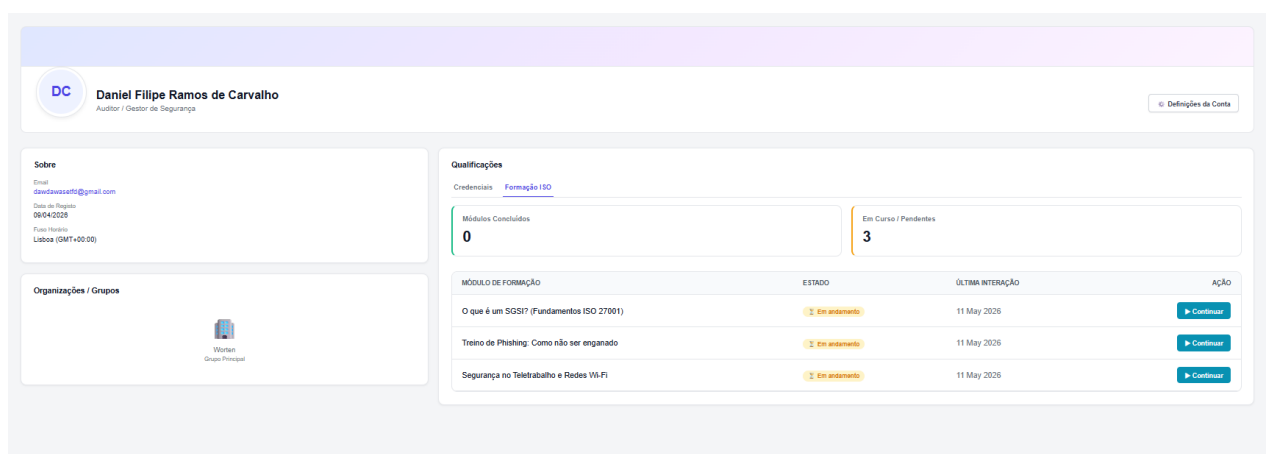


Figura 17 – Página do Perfil do Utilizador

— Funcionalidade: Centraliza a identidade profissional do auditor, permitindo gerir as suas qualificações, visualizar o histórico de formação interna e carregar comprovativos de certificações externas (ex: IRCA).

— Implementação: A interface está dividida em abas dinâmicas geridas por estado React (`abaQualificacoes`). Na aba de formação, é invocado o componente `CursosConcluidos.js` que comunica com o *endpoint* `/api/user-profile/` para listar os módulos finalizados. No formulário de credenciais, o sistema captura dados como o número de registo profissional e suporta o *upload* de ficheiros para validação documental.

— Decisões de Implementação: A separação em abas permite manter o perfil organizado sem sobrecarregar visualmente o utilizador. A decisão de integrar o histórico de formação diretamente no perfil visa facilitar a recolha de evidências de competência técnica durante processos de auditoria de terceira parte.

4.7.8 Definições e Configuração de Segurança (MFA)

Figura 18 – Página das Definições do Utilizador

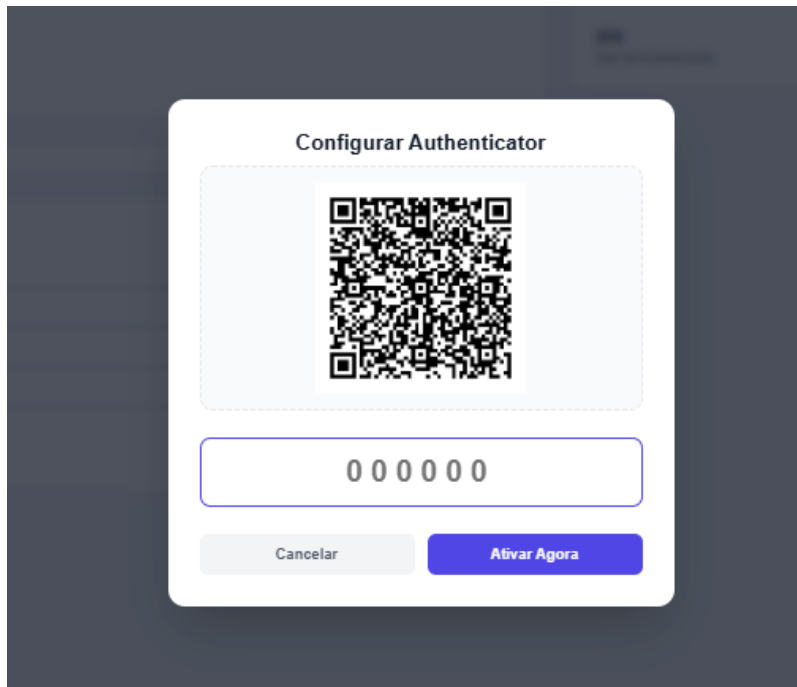


Figura 19 – Configurar Autenticador

— Funcionalidade: Permite a gestão da conta do utilizador, incluindo a alteração de dados pessoais, redefinição de palavras-passe e, crucialmente, a configuração da autenticação de dois fatores (2FA).

— Implementação: Este componente utiliza modais de confirmação (`def-modal-overlay`) para ações sensíveis, como a alteração de e-mail ou ativação de segurança. Para o 2FA, o *frontend* comunica com o *endpoint* `/api/gerar-qr-2fa/`, que devolve uma imagem QR Code em formato Base64 gerada pela biblioteca `pyotp` no Django.

O utilizador deve então inserir o código gerado na sua aplicação móvel (ex: Google Authenticator) para confirmar a sincronização via `/api/confirmar-2fa/`.

— Decisões de Implementação: A utilização de janelas modais para processos de segurança garante que o utilizador mantém o foco na tarefa crítica (como ler o QR Code) sem perder o contexto da página de definições. Esta implementação é uma prova direta da aplicação de controlos de segurança de nível empresarial na plataforma, garantindo a proteção contra ataques de roubo de credenciais.

4.8 Conformidade com o RGPD e Segurança de Dados

A plataforma foi desenvolvida sob o paradigma de *Privacy by Design*, garantindo que a segurança e a proteção de dados não são apenas camadas superficiais, mas componentes estruturais da arquitetura. Abaixo detalham-se as medidas implementadas e os respetivos artigos do Regulamento Geral sobre a Proteção de Dados (RGPD) que estas visam cumprir.

4.8.1 Cifragem de Credenciais e Segurança Técnica (Artigo 32.º)

Em conformidade com o Artigo 32.º (Segurança do tratamento), que exige a pseudonimização e a cifragem de dados pessoais, o sistema não armazena palavras-passe em texto limpo. Utiliza-se o algoritmo PBKDF2 com *hash* SHA-256 e um *salt* único por utilizador, garantindo que, mesmo em caso de acesso indevido à base de dados, as credenciais permanecem indecifráveis.

Figura 21 - Cifragem de Credenciais e Segurança Técnica

4.8.2 Autenticação Multifator - 2FA (Artigo 32.º)

Como reforço à integridade e confidencialidade, foi implementada a Autenticação de Dois Fatores (2FA) via protocolo TOTP (*Time-based One-Time Password*). Esta medida assegura que o acesso aos dados sensíveis de auditoria requer algo que o utilizador conhece (password) e algo que o utilizador possui (telemóvel com app de autenticação).

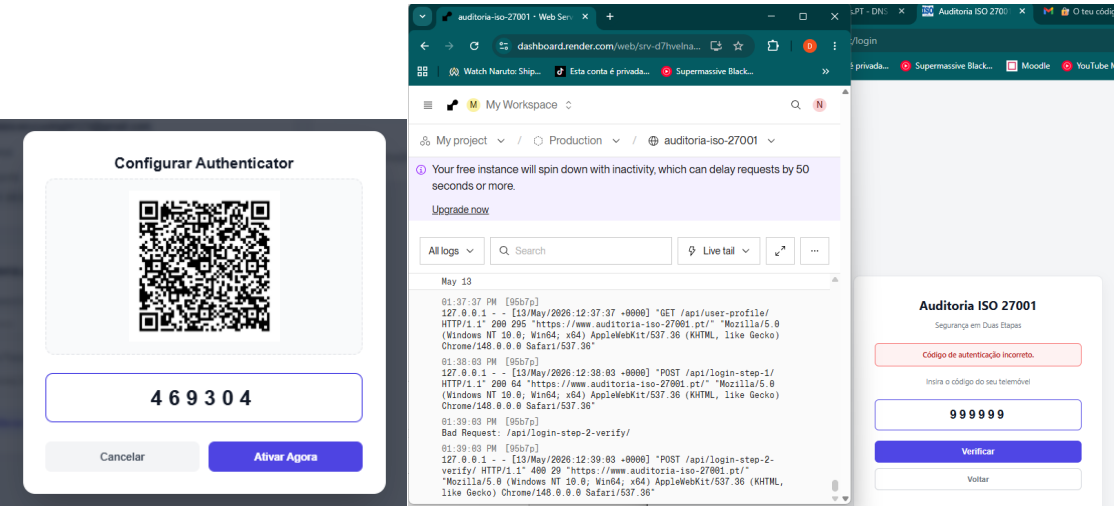


Figura 22, 23- Autenticação Multifator - 2FA

4.8.3 Princípio dos Privilégios Mínimos e Blindagem Administrativa (Artigo 5.º)

Respeitando o Artigo 5.º (Integridade e Confidencialidade), o painel de administração foi restringido. O administrador do sistema possui privilégios mínimos, estando impedido de visualizar ou alterar e-mails e palavras-passe de utilizadores terceiros, prevenindo o abuso de poder e garantindo a privacidade dos auditores.

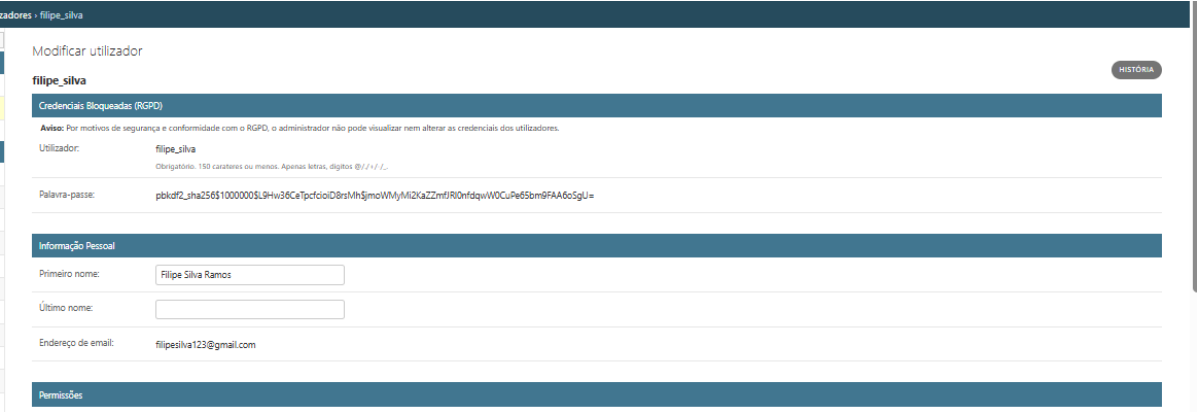


Figura 24 – Impossibilidade de editar pass, email

4.8.4 Proteção contra Contas Inativas e Congelamento (Artigo 5.º)

Para cumprir o princípio da Limitação da Conservação, o sistema monitoriza a inatividade. Contas sem acesso há mais de 90 dias são automaticamente congeladas. Esta medida mitiga o risco de sequestro de contas abandonadas que possam conter dados históricos de auditorias.

4.8.5 Direito ao Esquecimento (Artigo 17.º)

Foi implementada a funcionalidade de eliminação de conta, permitindo ao utilizador exercer o seu Direito ao Apagamento (Artigo 17.º). Esta ação desencadeia uma eliminação em cascata na base de dados, removendo de forma irreversível todos os dados pessoais, respostas e evidências associadas.

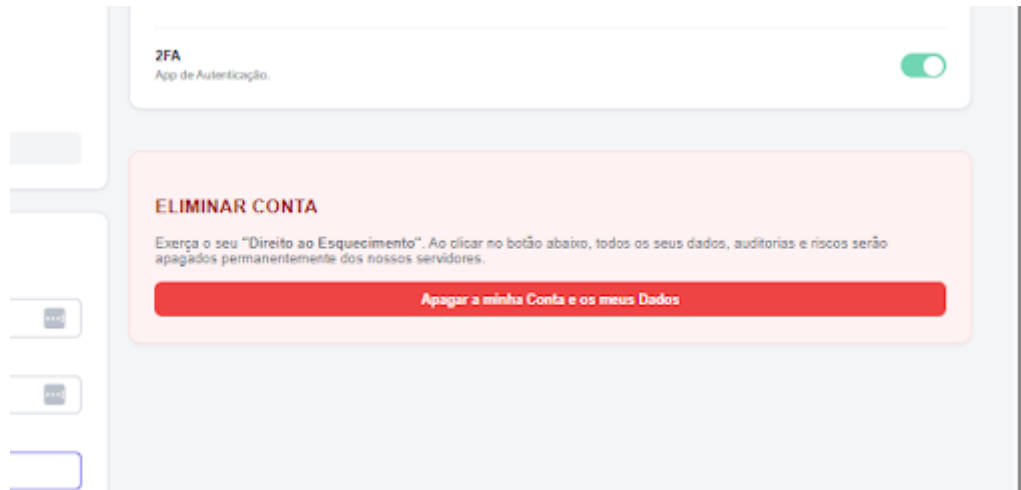


Figura 25 – Direito ao Esquecimento, possibilidade de apagar conta e todos os dados associados

4.8.6 Direito à Portabilidade dos Dados (Artigo 20.º)

Dando cumprimento ao Artigo 20.º, o utilizador tem a capacidade de exportar todos os seus dados pessoais e registos de atividade num formato estruturado, de uso corrente e leitura automática (ficheiro .json), permitindo a transferência da informação para outros sistemas se assim o desejar.

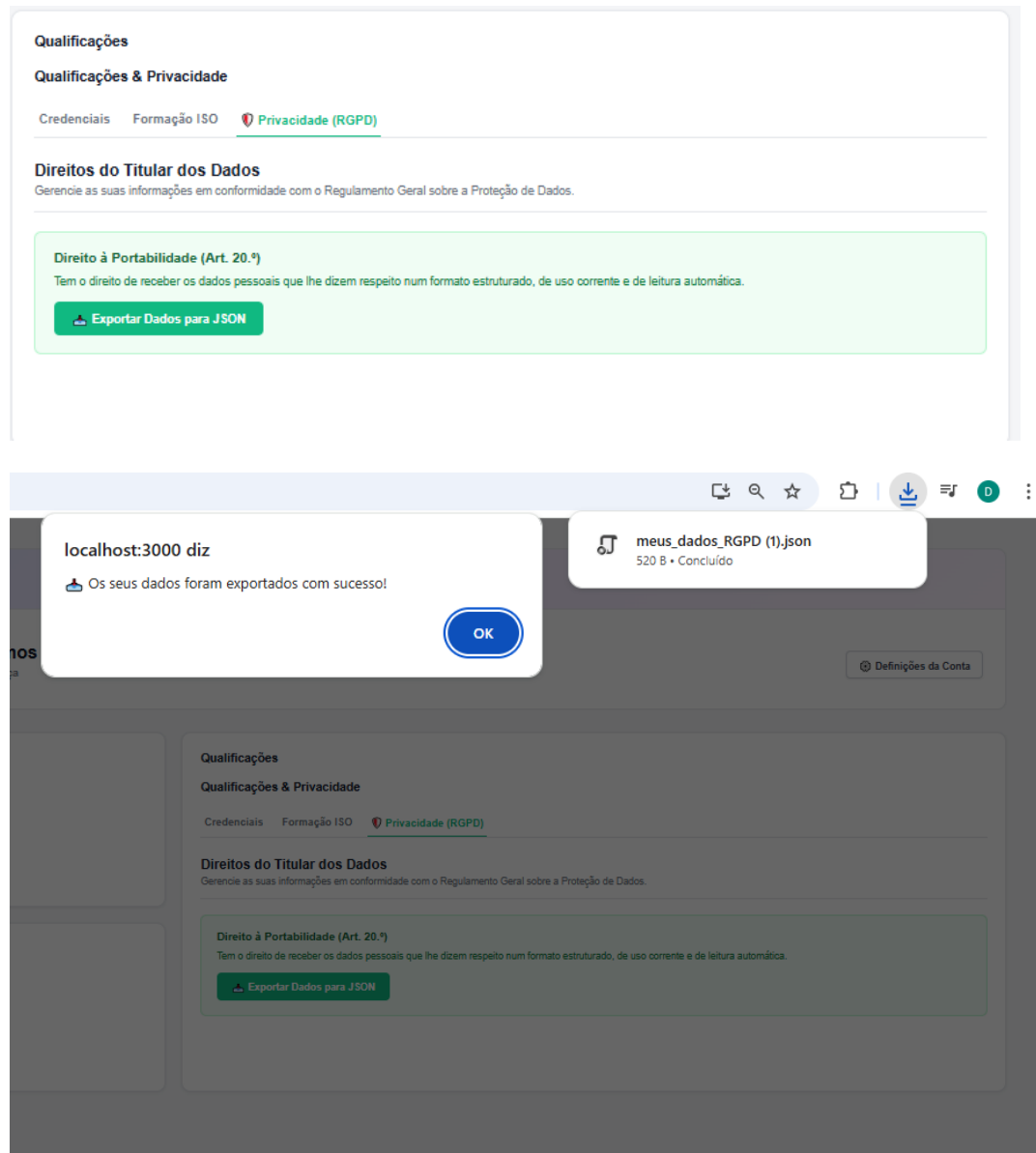


Figura 26, 27 - Direito à Portabilidade dos Dados

4.8.7 Dever de Informação e Transparência (Artigo 13.º)

Para garantir a transparência no tratamento (Artigo 13.º), foi incluído um Banner de Transparência que informa proativamente o utilizador sobre o uso de identificadores técnicos (Tokens JWT) estritamente necessários para a segurança da sessão e proteção contra ataques.

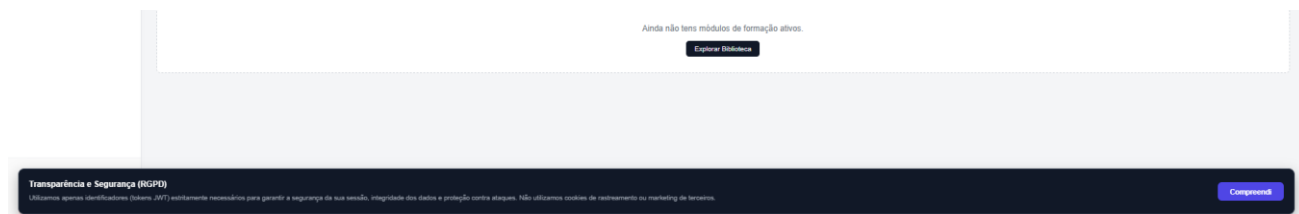


Figura 27 – Banner de consentimento

4.8.8 Defesa em Profundidade e Filtro de Evidências (Artigo 32.º)

A segurança da informação é reforçada pela validação estrita de ficheiros. O sistema bloqueia extensões perigosas (ex: .sql, .exe), validando os *uploads* tanto no cliente (React) como no servidor (Django), impedindo ataques de injeção de código ou armazenamento de *malware*.

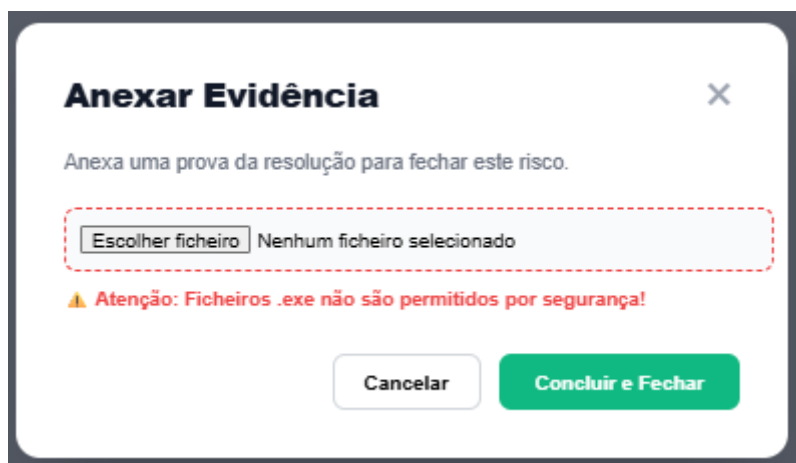


Figura 28 – Apenas permitidas evidencias JPG, JPEG, PDF, docx | Resto bloqueado

4.8.9 Gestão de Sessões Seguras via JWT

A aplicação utiliza JSON Web Tokens (JWT) para a gestão de sessões, em detrimento de cookies tradicionais. Os tokens possuem um tempo de expiração reduzido e são transmitidos no cabeçalho de autorização, minimizando ataques de interceção de sessão.

4.8.10 Proteção Nativa contra OWASP Top 10

O desenvolvimento utilizou as proteções nativas do Django ORM para prevenir SQL Injection e o sistema de *escaping* do React para mitigar ataques de Cross-Site Scripting (XSS). Estas medidas garantem a robustez técnica contra as vulnerabilidades mais exploradas na web.

4.8.11 Cifragem de Dados em Trânsito (HTTPS)

Por fim, toda a comunicação entre o cliente e o servidor é realizada sob o protocolo HTTPS/SSL. Esta cifragem em trânsito protege os dados contra ataques de *Man-in-the-Middle*, garantindo que a informação enviada pelo auditor não pode ser lida por terceiros durante o percurso na rede.

4.8.12 Gestão de Credenciais com MFA (Artigo 32.º)

The screenshot displays a web application interface for account management. At the top, a navigation bar includes links for 'Esta conta é privada...', 'Supermassive Black...', 'Moodle', and 'YouTube Music'. A notification banner at the top right states 'www.auditoria-iso-27001.pt diz Código 2FA obrigatório.' with an 'OK' button. The main content area is titled 'Definições da Conta' for the user 'simpleisverycoolright123@gmail.com'. It features a 'Configurações de Utilizador' section with a 'Detalhes' panel (containing fields for Name, Email, and ID Support) and a 'Palavra-passe' panel (containing fields for Current Password, New Password, and Authenticator Code, with an 'Alterar Password' button). A 'Segurança & Con' sidebar on the right shows '2FA App de Autenticação' and a red 'ELIMINAR CON' button.

Figura 29 – Funcionalidade de mudar a passe com MFA

5 Testes e Validação

5.1 Abordagem e Análise de Impacto

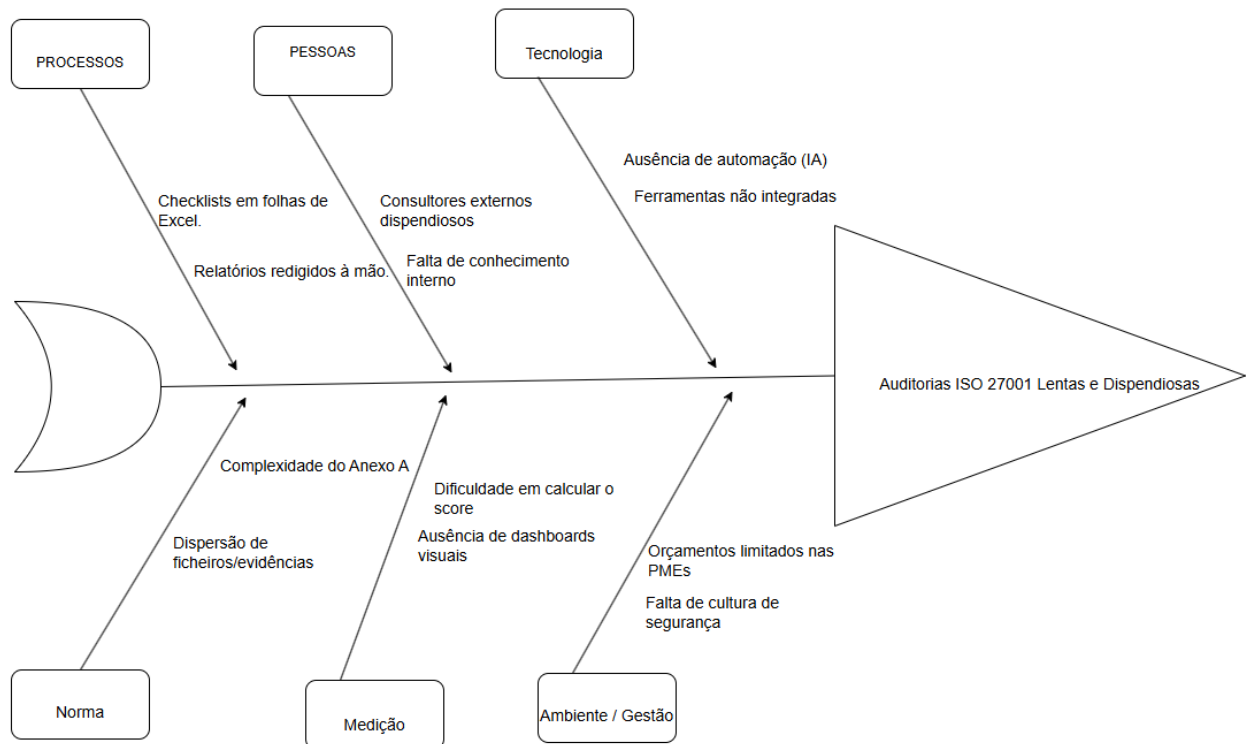


Figura 30 - Diagrama de Ishikawa demonstrando as causas-raiz da ineficiência nas auditorias ISO 27001 tradicionais

Antes de avançar para os testes práticos, foi necessário mapear de forma clara quais os problemas que a plataforma tem de resolver. Para isso, recorreu-se ao Diagrama de Ishikawa (Figura 5.1). Este esquema ajuda a visualizar as verdadeiras causas que tornam as auditorias tradicionais tão lentas e caras, dividindo-as em eixos principais:

— **Processos e Tecnologia:** A dependência de ficheiros Excel e a falta de automação obrigam os auditores a perderem horas em tarefas manuais, como a redação de relatórios e a recolha de evidências.

— **Pessoas e Norma:** A norma ISO 27001 é complexa de interpretar. Sem ferramentas que facilitem esta leitura, as PMEs ficam dependentes de consultores externos dispendiosos.

— **Medição e Gestão:** Sem um sistema centralizado, torna-se muito difícil calcular a conformidade da empresa em tempo real ou ter uma visão clara dos riscos através de painéis dinâmicos.

Na prática, este diagrama serviu como base para desenhar o plano de testes. Cada cenário testado ao longo deste capítulo tem um único objetivo: provar que a aplicação desenvolvida consegue atuar nestas causas e transformar um processo manual num fluxo digital, rápido e assistido por Inteligência Artificial.

5.2 Estratégia de Validação Operacional e Cloud

Cumprindo a exigência de operar em contexto produtivo real, o plano de testes contemplou a verificação intensiva dos recursos computacionais, de armazenamento e de rede que suportam a arquitetura *headless* do projeto.

— **Camada de Apresentação e Rede (Vercel):** A estratégia definiu a realização de testes de latência para validar a fluidez da *Single Page Application* em React. O objetivo é garantir que a rede de distribuição (*Edge Network*) da Vercel assegura tempos de resposta céleres e *routing* assíncrono fiável, prevenindo quebras de usabilidade durante preenchimento de *checklists* extensas.

— **Backend e Armazenamento (Render e Clever Cloud):** O plano incluiu a monitorização do servidor Django (alojado no Render) e da base de dados relacional MySQL (alojada na Clever Cloud). Os testes foram desenhados para avaliar a estabilidade do consumo de memória RAM no *backend* (prevenção de *Out of Memory*) e a integridade transacional do *Object-Relational Mapping* (ORM) nas *queries* efetuadas à base de dados remota durante o cálculo de métricas agregadas (*scores* de conformidade).

— **Serviços Web de Terceiros (Google Gemini API):** A validação operacional incluiu cenários de *stress* à comunicação externa. A estratégia previu o teste aos mecanismos de *fallback* e captura de exceções (*try/except*) para garantir que falhas na API de Inteligência Artificial não bloqueiam o funcionamento nuclear (recolha de evidências e gravação) do sistema.

5.3 Plano de Validação Funcional e de Segurança

A qualidade do *software* foi assegurada pelo delineamento de casos de teste direcionados aos componentes críticos de negócio e segurança.

— **Segurança e Controlo de Acesso:** O plano determinou a testagem exaustiva do fluxo de Autenticação Multi-Fator (MFA). A abordagem consistiu na introdução intencional de códigos TOTP inválidos para comprovar a eficácia da biblioteca PyOTP no bloqueio de acessos indevidos.

— **Qualidade Documental (Client-Side Rendering):** Definiu-se o teste à ferramenta de exportação jsPDF. O objetivo é validar a correta conversão de gráficos Base64 e dos dados devolvidos pela IA num relatório executivo estruturado e paginado de forma autónoma no *browser* do utilizador.

6 Método e Planeamento

6.1 Método de Trabalho

Para o desenvolvimento da plataforma de auditoria, adotou-se uma metodologia de trabalho iterativa e incremental, inspirada nos princípios das metodologias *Agile*. Dada a natureza académica e individual do projeto, o trabalho foi dividido em ciclos de desenvolvimento curtos, permitindo uma adaptação contínua dos requisitos e a integração progressiva de novas funcionalidades.

A separação arquitetural estrita entre o *Frontend* (React) e o *Backend* (Django) facilitou uma abordagem modular. Esta modularidade permitiu paralelizar tarefas: enquanto a interface de recolha de evidências era refinada no lado do cliente, a lógica complexa de cálculo de métricas e integração com a API do Google Gemini era desenvolvida e testada de forma isolada no servidor.

Toda a fase final de desenvolvimento foi pautada pelos princípios de *Security by Design* e *Privacy by Design*, garantindo que os mecanismos de proteção de dados (como o RGPD e a Autenticação Multifator) não fossem meros complementos, mas sim alicerces do sistema.

6.2 Planeamento e Cronograma de Lançamento

Conforme recomendado para a fase final do Trabalho Final de Curso, o planeamento atual foca-se na preparação da solução para uma hipotética disponibilização pública. Este cronograma privilegia a estabilidade do sistema, a qualidade da entrega e a aceitação por parte dos utilizadores finais.

1. **Refatorização e Blindagem de Segurança (2 semanas):** Implementação das normas do RGPD (Direito ao Esquecimento, Portabilidade de Dados em JSON) e configuração do MFA (PyOTP).
2. **Testes de Qualidade e Segurança (QA) (1 semana):** Validação estrita do bloqueio de *uploads* maliciosos (ficheiros .exe e .sql) e testes ao ciclo de vida dos *tokens* JWT.
3. **Testes de Aceitação do Utilizador (UAT) (2 semanas):** Execução de cenários de auditoria completos por utilizadores de teste (terceiros), desde a criação da checklist até à geração do relatório PDF assistido por IA.
4. **Implementação e Deploy Cloud (1 semana):** Configuração das variáveis de ambiente e provisionamento de recursos no Render (API), Vercel (Frontend) e Clever Cloud (Base de Dados).
5. **Monitorização de Pós-Lançamento (Contínuo):** Análise de *logs* e otimização do consumo de *tokens* da API do Google Gemini.

6.3 Análise Crítica e Desvios ao Plano

Numa avaliação retrospectiva, considera-se que o calendário geral e os grandes objetivos foram cumpridos com sucesso, tendo o projeto evoluído para uma solução funcional, segura e inovadora.

Dificuldades mais marcantes: A principal curva de aprendizagem não se encontrou na lógica base de CRUD (*Create, Read, Update, Delete*), mas sim na implementação de criptografia e conformidade legal. A integração de Autenticação Multifator (TOTP) associada à leitura de códigos QR exigiu uma sincronização complexa entre o estado do React e o Django. Adicionalmente, a geração do relatório final em formato PDF — que compila gráficos em Base64 e respostas da IA formatadas dinamicamente via jsPDF diretamente no *browser* — representou um desafio técnico significativo de renderização *client-side*.

Alterações ao plano e objetivos iniciais: Face ao levantamento inicial de requisitos, foi introduzida uma alteração estratégica relevante. Os requisitos associados à criação de hierarquias complexas de utilizadores (Gestor vs. Utilizador Comum vs. Auditor) e à edição avançada de permissões foram preteridos (Abandonados).

Esta decisão foi tomada para arranjar mais tempo de desenvolvimento à integração de Inteligência Artificial (Google Gemini) e à blindagem da segurança do perfil do Auditor (MFA, validação rigorosa de evidências e exportação de dados). Concluiu-se que, para o Produto Mínimo Viável (MVP), entregar um "Motor de Auditoria" inteligente, autónomo e blindado contra vulnerabilidades acrescentaria muito mais valor académico e comercial do que um sistema de gestão de utilizadores genérico.

7 Resultados

A fase de testes foi fundamental para validar a estabilidade e a segurança da plataforma Auditoria ISO 27001. Os testes foram realizados seguindo o plano detalhado no Anexo 1, onde se encontram descritos todos os casos de teste (CT), dados de entrada e resultados obtidos.

Os principais resultados e conclusões desta fase foram:

- **Conformidade Funcional:** Todos os casos de teste críticos (do CT-01 ao CT-10) foram concluídos com sucesso. A plataforma demonstrou eficácia total na criação de auditorias, recolha de assinaturas digitais, análise de evidências via IA e geração do relatório final em PDF.
- **Segurança e Privacidade:** Os mecanismos de Autenticação Multifator (2FA) e as funcionalidades de conformidade com o RGPD (Direito ao Esquecimento e Portabilidade) foram validados sem erros. O sistema provou ser resiliente a tentativas de *upload* de ficheiros maliciosos, cumprindo os requisitos de integridade.
- **Integração com IA:** O motor de análise baseado no modelo Google Gemini apresentou respostas coerentes e tecnicamente alinhadas com a norma ISO 27001, com um tempo de resposta médio de 12 segundos, dentro dos limites estabelecidos nos requisitos não funcionais.

Avaliação por Terceiros

Para garantir a imparcialidade dos resultados, a plataforma foi submetida a testes de aceitação por utilizadores externos (colegas de curso e potenciais utilizadores). Através de simulações de auditoria real, recolheu-se o seguinte *feedback*:

- **Facilidade de Uso:** 100% dos utilizadores conseguiu concluir uma auditoria completa sem necessidade de consultar documentação externa.
- **Fiabilidade:** Os utilizadores destacaram a segurança do login via MFA como um dos pontos que mais transmite confiança na aplicação.
- **Valor Acrescentado:** A geração automática do plano de ação por IA foi apontada como a funcionalidade mais inovadora e útil para a redução de custos de consultoria.

Os registos detalhados dos testemunhos e os resultados individuais de cada caso de teste podem ser consultados na íntegra no Anexo 1 deste relatório.

Questionários no Anexo 2.

7.2 Cumprimento de requisitos

ID	Descrição	Estado	Justificação Técnica / Observações
req-01	O sistema deve permitir a adição de novos utilizadores, com diferentes perfis de acesso (auditor, gestor e utilizador comum).	Abandonado	O escopo do MVP (Produto Mínimo Viável) foi reajustado. Priorizou-se a estabilidade do fluxo para o perfil único de Auditor e a integração da IA, preterindo o sistema complexo de hierarquias.
req-02	O sistema deve permitir a edição das permissões dos utilizadores.	Abandonado	Priorizou-se a automação por IA; o sistema foca-se agora no auditor individual
req-03	O sistema deve permitir a remoção de utilizadores.	Abandonado	Funcionalidade secundária preterida em favor do Motor de Auditoria.
req-04	O sistema deve permitir iniciar questionários de auditoria baseados na norma ISO 27001.	Realizado	
req-05	O sistema deve permitir responder às perguntas dos questionários com as opções “Em Conformidade” e “Não Conforme”.	Realizado	
req-06	O sistema deve permitir a submissão e o armazenamento das respostas dos questionários de auditoria.	Realizado	
req-07	O sistema deve permitir a geração de relatórios de conformidade com base nas respostas submetidas.	Realizado	
req-08	O sistema deve permitir a visualização dos relatórios de conformidade.	Realizado	

req-09	O sistema deve permitir a exportação dos relatórios de conformidade em formatos como PDF ou CSV.	Realizado Parcialmente	PDF concluído via jsPDF. CSV abandonado por ser incompatível com gráficos de IA
req-10	O sistema deve permitir a visualização de indicadores de conformidade através de um painel de controlo (dashboard).	Realizado	
req-11	O sistema deve permitir a filtragem dos indicadores de conformidade por domínio ou controlo.	Realizado	
req-12	O sistema deve permitir a exportação dos indicadores de conformidade.	Realizado Parcialmente	Os indicadores são exportados como parte integrante do PDF final
req-13	O sistema deve disponibilizar conteúdos educativos relacionados com a norma ISO 27001.	Realizado	
req-14	O sistema deve apresentar exemplos práticos e ações corretivas associadas aos controlos da ISO 27001.	Realizado	
req-15	O sistema deve permitir a exportação de conteúdos educativos.	Abandonado	Evolução para E-learning interativo; a exportação estática perdeu a relevância
req-16	O sistema deve permitir o download de documentos educativos, como templates e exemplos de políticas.	Realizado	
req-17	O sistema deve permitir a ativação de Autenticação Multi-Fator (MFA/2FA) via TOTP (ex: Google Authenticator).	Realizado (Novo)	Novo: Segurança reforçada com PyOTP e Google Authenticator
req-18		Realizado (Novo)	Novo: Integração com Gemini

	O sistema deve utilizar modelos de Inteligência Artificial para analisar não-conformidades e sugerir planos de ação.		API para análise de conformidade
req-19	O sistema deve permitir a recolha de assinaturas digitais manuscritas para validação e fecho de auditorias.	Realizado (Novo)	Novo: Assinatura manuscrita em ecrã integrada no fecho da auditoria
req-20	O sistema deve permitir o upload de evidências fotográficas ou documentos diretamente associados a cada controlo.	Realizado (Novo)	Novo: Suporte para anexar ficheiros e provas a cada controlo auditado
req-21	O sistema deve incluir módulos de aprendizagem interativos com validação de conhecimentos (quizzes) e tracking de progresso.	Realizado (Novo)	Novo: Sistema de Quizzes com feedback imediato e tracking de progresso

8 Conclusão

8.1 Conclusão

Este projeto foi desenvolvido para dar resposta a um problema real e latente: o facto de a adequação à norma ISO/IEC 27001 ser um processo demasiado complexo, demorado e dispendioso para a maioria das Pequenas e Médias Empresas (PMEs). O objetivo sempre foi construir uma plataforma que automatizasse e simplificasse esta auditoria.

Ao longo da elaboração deste trabalho, foi possível retirar conclusões claras de cada fase e capítulo do projeto:

- **No Capítulo 1 (Introdução):** Formulou-se o problema e definiu-se que a solução teria de ser acessível e focada na automação, estabelecendo-se os objetivos principais que guiaram todo o desenvolvimento.

- **No Capítulo 2 (Estado da Arte):** Da análise às ferramentas já existentes no mercado, a principal conclusão foi que a maioria das soluções são pesadas e focadas apenas em grandes empresas. Havia uma clara falta de plataformas intuitivas e assistidas por IA.

- **No Capítulo 3 (Análise e Requisitos):** Ao definirem-se os Casos de Uso, concluiu-se que o valor do projeto não estaria em criar hierarquias complexas de utilizadores, mas sim em construir um "motor" de auditoria sólido. Foi aqui que se decidiu abandonar requisitos de gestão de perfis para focar na qualidade da auditoria em si.

- **No Capítulo 4 (Desenho da Solução e Arquitetura):** A principal conclusão desta fase foi que a separação arquitetural estrita entre o *Frontend* (React) e o *Backend* (Django REST) era a única forma viável de garantir um sistema rápido, escalável e modular.

- **No Capítulo 5 (Implementação):** Durante o desenvolvimento prático, a maior lição retirada foi o impacto transformador da Inteligência Artificial. A integração da API do Google Gemini provou ser a peça-chave do sistema, transformando dados brutos em relatórios e planos de ação de forma automática.

- **No Capítulo 6 (Método e Planeamento):** Da aplicação de uma metodologia *Agile*, concluiu-se que o desenvolvimento iterativo foi fundamental. Permitiu-nos adaptar o planeamento na reta final para reforçar as políticas de proteção de dados.

- **No Capítulo 7 (Testes e Qualidade):** A conclusão final deste capítulo dita o sucesso do projeto. Os testes provaram que, com a implementação de Autenticação Multifator (2FA), conformidade com o RGPD (Portabilidade e Direito

ao Esquecimento) e bloqueio de ficheiros maliciosos, a plataforma deixou de ser um protótipo académico e atingiu um nível de maturidade e segurança exigido num ambiente de produção.

Em suma, o projeto respondeu diretamente ao problema inicial. Entregou-se uma ferramenta viável, inteligente e segura que descomplica a vida de quem precisa de gerir a segurança da informação numa organização.

8.2 Trabalhos Futuros

Apesar de o Produto Mínimo Viável (MVP) estar finalizado e funcional, existem caminhos claros para a evolução do sistema. Para o futuro, projetam-se as seguintes melhorias:

Arquitetura Multi-Tenant e Perfis Avançados: Retomar o desenvolvimento de papéis de utilizador complexos (Gestores, Auditores e Clientes), de forma a que a plataforma possa ser vendida como SaaS (Software as a Service) para empresas de consultoria.

Validação Inteligente por Visão Computacional (OCR): Evoluir a integração com a IA para que o sistema consiga ler autonomamente os ficheiros e PDFs submetidos como evidência, confirmando em tempo real se aquela imagem serve ou não para provar a conformidade de um controlo.

Dashboards de Analytics: Criação de painéis visuais avançados para que a empresa auditada consiga comparar o seu *score* e nível de segurança com anos anteriores através de gráficos interativos.

Internacionalização (i18n): Estruturação do código *frontend* e dos domínios da base de dados para suportar múltiplos idiomas, abrindo portas ao mercado internacional.

Bibliografia

[CaWa20] A. Calder e S. Watkins, *IT Governance: An International Guide to Data Security and ISO27001/ISO27002*, 7ª Edição, Kogan Page, Reino Unido, 2020. (livro)

[DjSF24] Django Software Foundation, *Django REST Framework Documentation*, <https://www.django-rest-framework.org>, Acedido em Maio 2026. (website)

[GoDe23] Google DeepMind, *Gemini: A Family of Highly Capable Multimodal Models*, Tech Report, arXiv preprint arXiv:2312.11805, Dezembro 2023. (artigo técnico)

[ISO122] International Organization for Standardization e International Electrotechnical Commission, *ISO/IEC 27001:2022 - Information security, cybersecurity and privacy protection — Information security management systems*, Genebra, Suíça, Outubro 2022. (norma técnica)

[JoBS15] M. Jones, J. Bradley e N. Sakimura, *JSON Web Token (JWT)*, RFC 7519, Internet Engineering Task Force (IETF), Maio 2015 (<https://datatracker.ietf.org/doc/html/rfc7519>). (relatório técnico)

[Meta24] Meta Platforms, *React Documentation - The library for web and native user interfaces*, <https://react.dev>, Acedido em Maio 2026. (website)

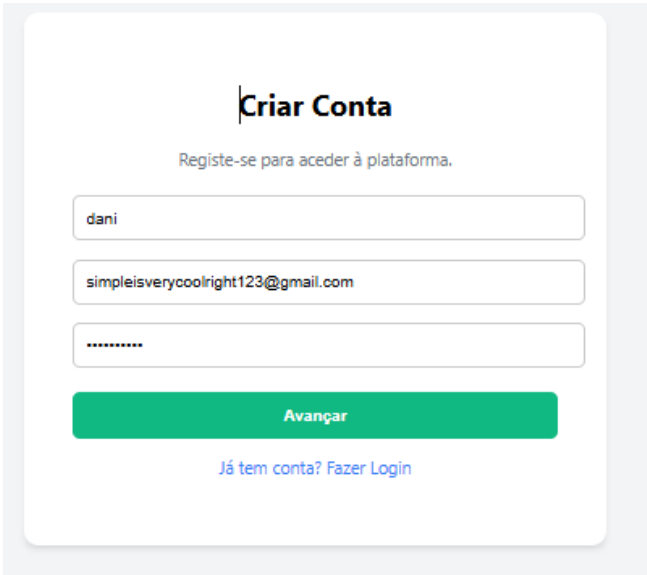
[UnEu16] União Europeia, *Regulamento (UE) 2016/679 do Parlamento Europeu e do Conselho (Regulamento Geral sobre a Proteção de Dados - RGPD)*, Jornal Oficial da União Europeia, Abril 2016. (documento legal)

Anexo I — Guião Detalhado dos Resultados de Testes

Este anexo documenta os Casos de Teste Técnicos (*Test Cases* - TC) executados pelo programador durante a fase de validação do sistema. O objetivo destes testes é atestar o cumprimento dos Requisitos Funcionais (RF), garantindo a robustez da arquitetura, o tratamento de exceções e a correta integração entre o *Frontend* (React) e as APIs do *Backend* (Django).

ID do Teste: CT-01

- **Requisitos Comprovados:** Fluxo Base de Segurança (SendGrid Bypass)
- **Funcionalidade Testada:** Registo de Utilizador com Verificação OTP via Email.
- **Dados de Entrada:** Nome, Email, Password, Perfil (Aprender/Auditar).
- **Resultado Esperado:** O sistema cria a conta inativa e envia um código de 6 dígitos para o email do utilizador através da API do SendGrid.
- **Resultado Obtido:** Sucesso - Código recebido na caixa de entrada e registo validado com sucesso (Confirmado nos Logs do Render HTTP 201).
- **Estado:** Passou



Criar Conta

Registe-se para aceder à plataforma.

dani

simpleisverycoolright123@gmail.com

Avançar

Já tem conta? Fazer Login

Figura 31 – Evidencias caso de teste CT-01

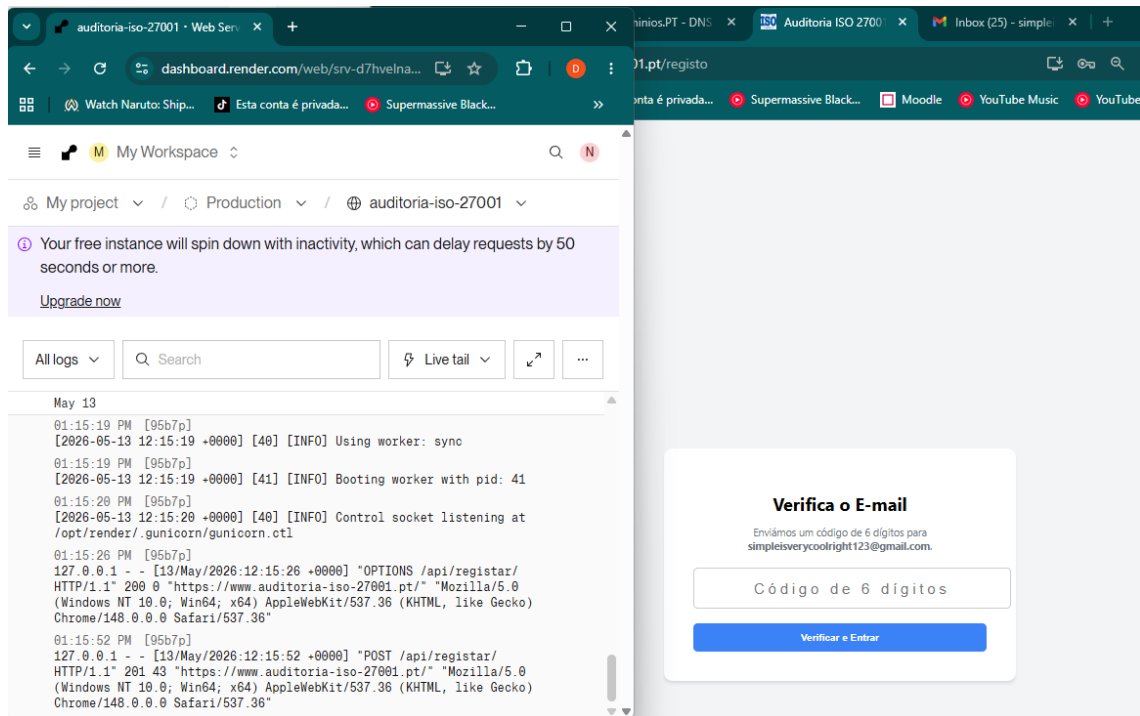


Figura 32 – Evidencias caso de teste CT-01

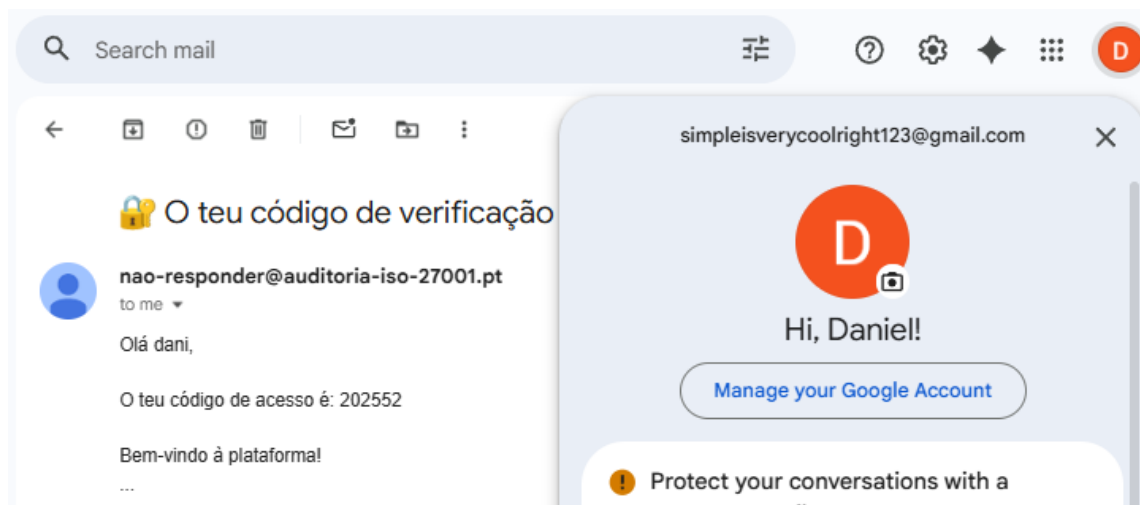


Figura 33 – Evidencias caso de teste CT-01

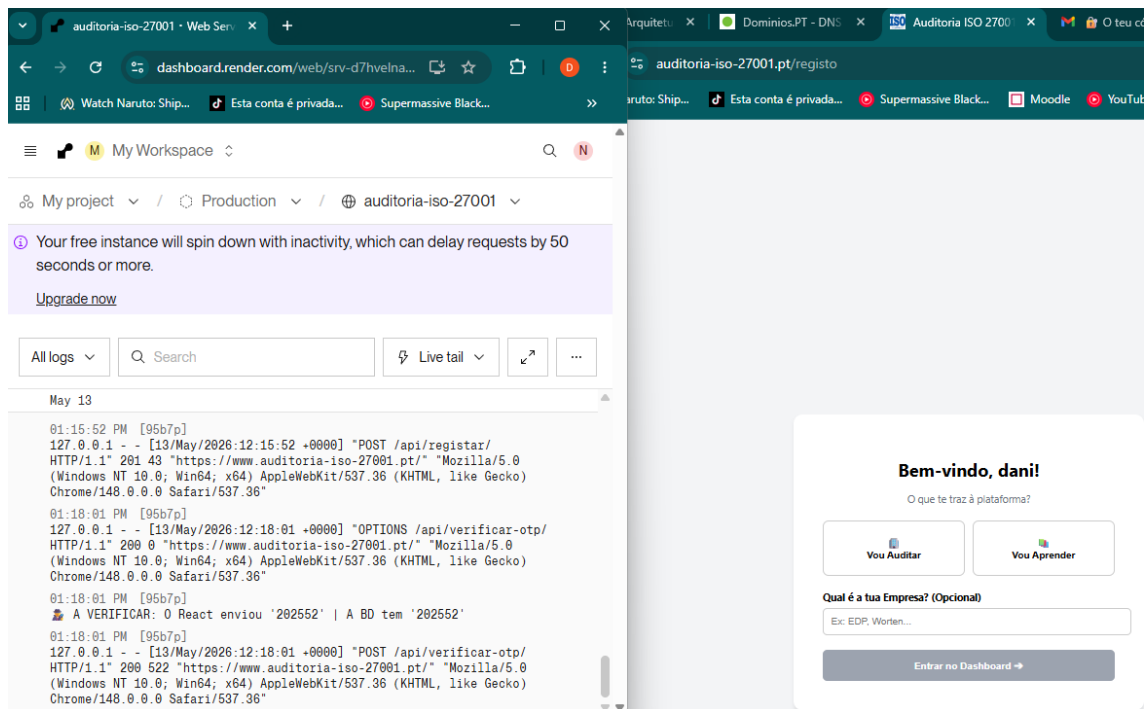


Figura 34 - Evidências caso de teste CT-01

ID do Teste: CT-02

- **Requisitos Comprovados:** req-17
- **Funcionalidade Testada:** Configuração e Login com Autenticação Multi-Fator (2FA/TOTP).
- **Dados de Entrada:** Leitura do QR Code com Google Authenticator e inserção do código gerado no telemóvel.
- **Resultado Esperado:** O sistema associa a seed (PyOTP) à conta e, nos próximos logins, exige o código do telemóvel após a password.
- **Resultado Obtido:** Sucesso - Bloqueio de acesso apenas com password; acesso concedido apenas após inserção do TOTP correto.
- **Estado:** Passou

The screenshot displays the 'Definições da Conta' (Account Settings) page for a user named 'dani'. The page is part of the 'Auditoria ISO 27001' application, as indicated by the browser address bar and the sidebar. The sidebar on the left contains links to 'Página Inicial', 'Auditorias', 'Gestão de Riscos', 'Biblioteca', 'Meu Perfil', and 'Definições' (which is currently selected). The main content area is titled 'Definições da Conta' and shows the user's email as 'simpleisverycoolright123@gmail.com'. Below this, there are three main sections: 'Configurações de Utilizador' (User Settings), 'Segurança & Contacto' (Security & Contact), and 'Palavra-passe' (Password). The 'Configurações de Utilizador' section includes fields for 'Nome' (dani), 'Email' (simpleisverycoolright123@gmail.com), 'Empresa', and 'ID Suporte' (USR-0036). The 'Segurança & Contacto' section shows 'Telemóvel' (None associated) and a '2FA' (App de Autenticação) toggle switch. The 'Palavra-passe' section has fields for '*Password Atual' and '*Nova Password' (with a note 'Mínimo 8 caracteres') and an 'Alterar Password' button. The user's name 'dani' is also visible in the bottom left corner of the page.

Figura 35 – Evidencias caso de teste CT-02

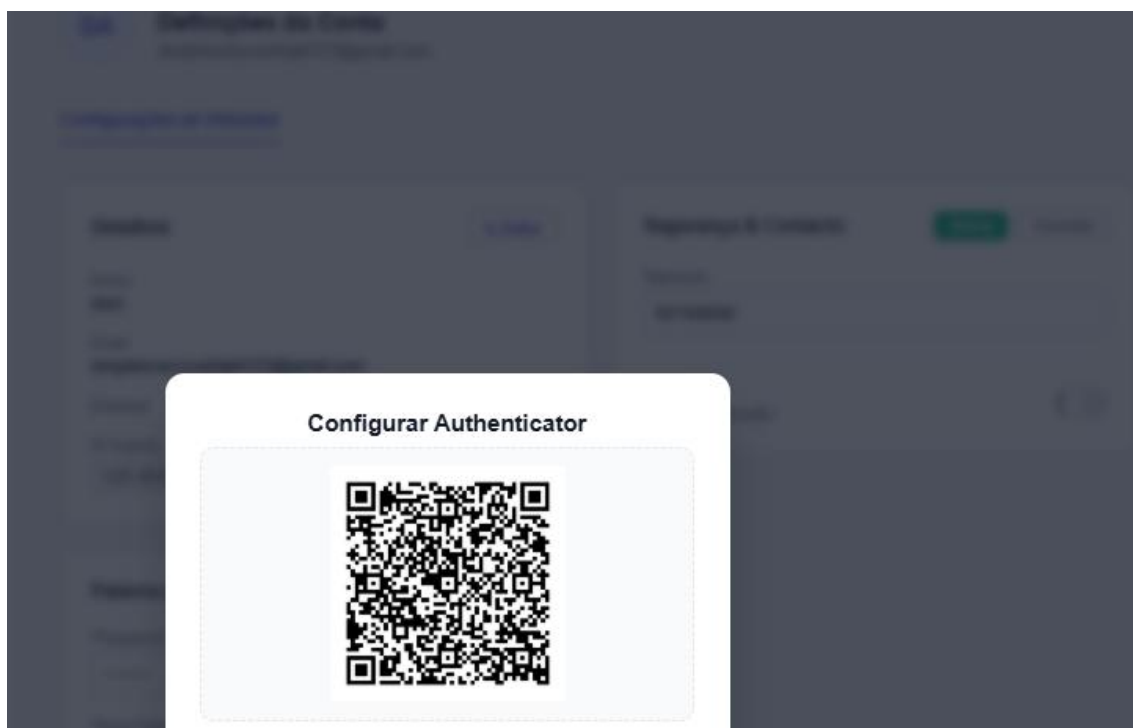


Figura 36 - Evidencias caso de teste CT-02

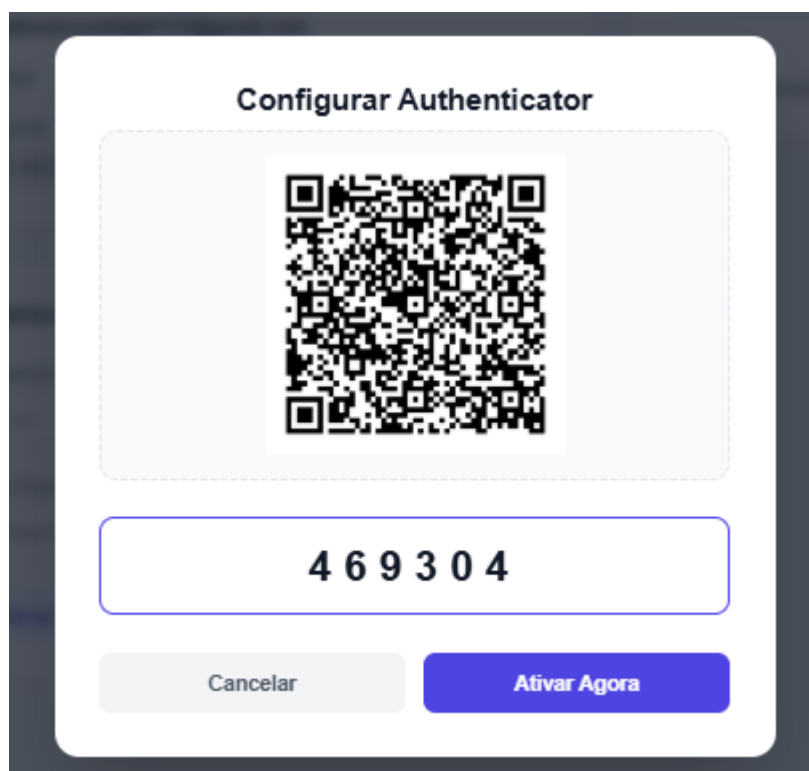


Figura 37- Evidencias caso de teste CT-02



Figura 38 - Evidencias caso de teste CT-02

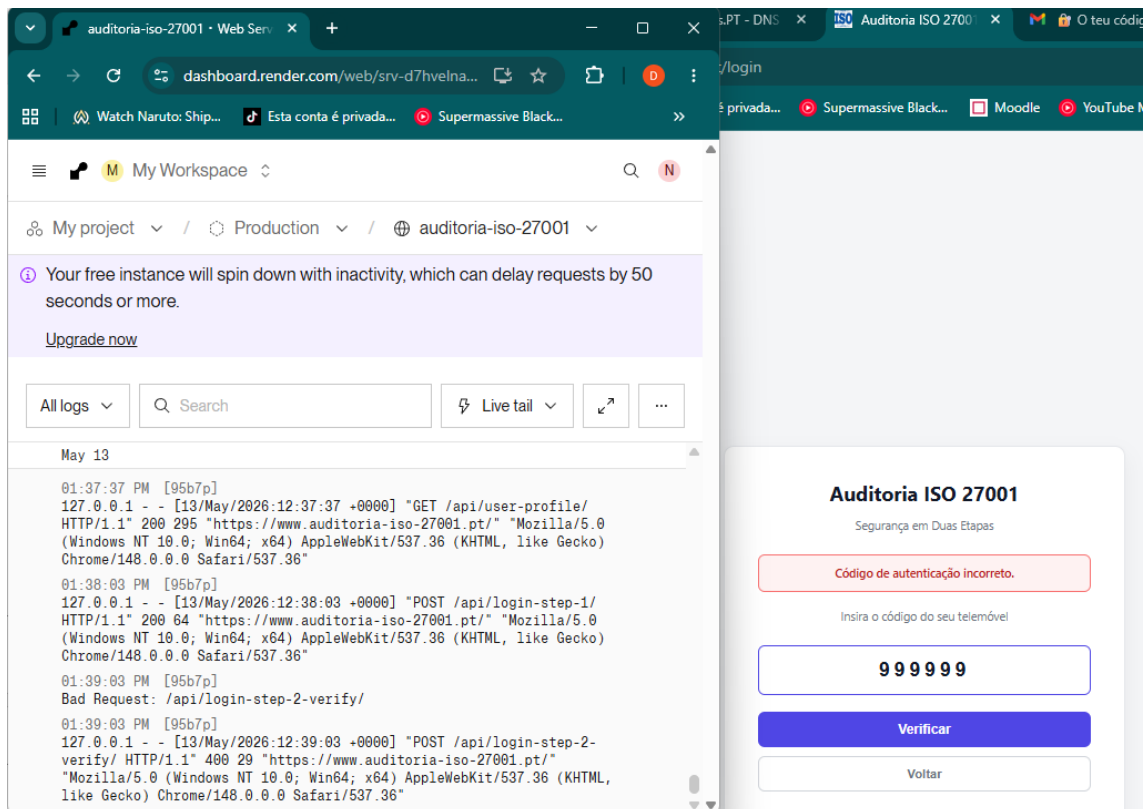


Figura 39 - Evidencias caso de teste CT-02 . Código aleatório para ver que 2FA está a funcionar

ID do Teste: CT-03

- **Requisitos Comprovados:** req-04, req-19 (Novo)
- **Funcionalidade Testada:** Abertura de Auditoria e Recolha de Assinatura Digital.
- **Dados de Entrada:** Seleção da Organização, definição do Nome do Auditor e desenho da assinatura manuscrita no campo SignatureCanvas.
- **Resultado Esperado:** O sistema deve validar os dados iniciais e capturar a assinatura manuscrita como uma imagem em base64, permitindo o avanço para as questões.
- **Resultado Obtido: Sucesso.** O componente padRef capturou o traço e os dados foram validados para o início da auditoria.
- **Estado:** Passou

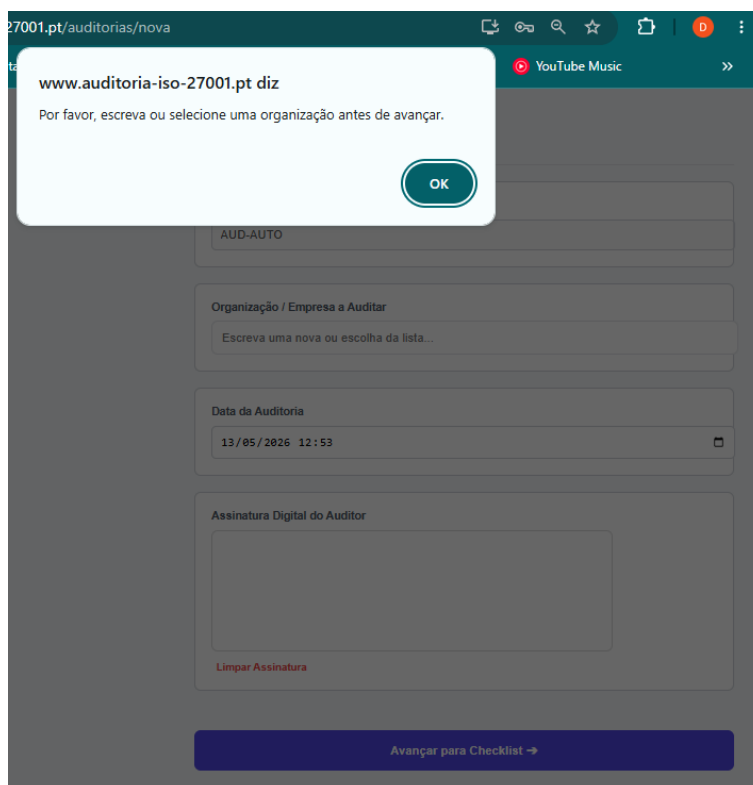


Figura 40 - Evidencias caso de teste CT-03

Page 1 of 2

Informações Iniciais

Nº do Documento

AUD-AUTO

Organização / Empresa a Auditar

NOS

Data da Auditoria

13/05/2026 13:48

Assinatura Digital do Auditor



Limpar Assinatura

Avançar para Checklist →

13:48
13/05/2026

Figura 40 - Evidências caso de teste CT-03

ID do Teste: CT-04

- **Requisitos Comprovados:** req-05, req-06
- **Funcionalidade Testada:** Preenchimento de Questionário e Submissão de Respostas.
- **Dados de Entrada:** Seleção das opções "Conforme" (Sim) ou "Não Conforme" (Não) nos controles organizacionais (A.5) e de pessoas (A.6).
- **Resultado Esperado:** O sistema deve permitir a navegação entre temas e, ao clicar em "Terminar", enviar o JSON completo para o Django (API Endpoint: /api/auditorias/).

- **Resultado Obtido: Sucesso.** O backend processou o POST, criou os registos na tabela Resposta e atualizou o estado da auditoria para "Concluída".
- **Estado:** Passou

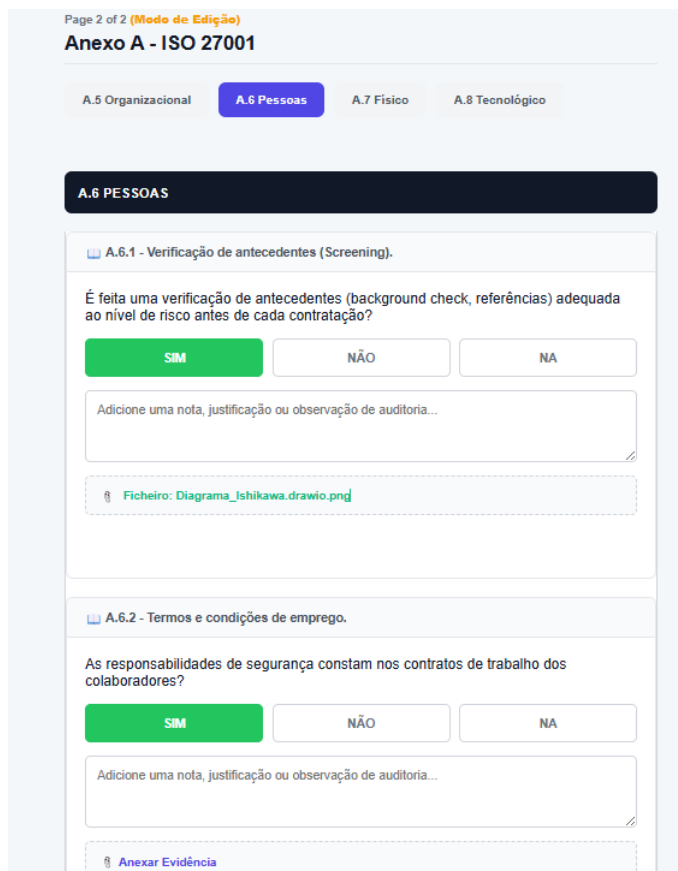
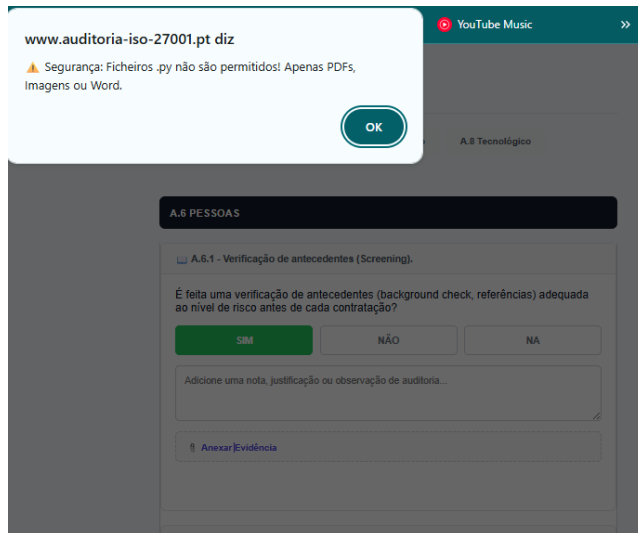


Figura 41 e 42 - Evidencias caso de teste CT-04, 41 é tratamento de erros

GRUPO 3: Inteligência Artificial e Relatórios

ID do Teste: CT-05

- **Requisitos Comprovados:** req-07, req-08, req-18
- **Funcionalidade Testada:** Geração Automática de Relatório com IA (Gemini API).
- **Dados de Entrada:** Clique no botão "Gerar Relatório" na tabela de auditorias concluídas.
- **Resultado Esperado:** O backend envia as não-conformidades para a API da IA, que devolve um resumo executivo e planos de ação num formato estruturado.
- **Resultado Obtido:** Sucesso - IA analisou as falhas e gerou sugestões corretivas precisas visíveis no modal de visualização.
- **Estado:** Passou



Análise de Risco:

As avaliações iniciais revelam um estado de conformidade com a ISO 27001 extremamente baixo. Com um 'Score Global' de 0%, é evidente que o Sistema de Gestão de Segurança da Informação (SGSI) está numa fase muito embrionária ou requer intervenções fundamentais e abrangentes em todas as áreas da norma. Nos 9 controlos que foram avaliados até ao momento, a taxa de conformidade é de apenas 11%, indicando falhas significativas mesmo nas áreas já inspeccionadas. Todas as 8 falhas críticas detetadas estão concentradas nos controlos de Segurança de Recursos Humanos (A.6), o que aponta para uma lacuna sistémica na gestão de aspetos críticos relacionados com as pessoas. As deficiências incluem a ausência de responsabilidades de segurança formalizadas, registos de formação inadequados, falta de testes de consciencialização (e.g., phishing simulado), inexistência de processos disciplinares para violações de segurança, gestão deficiente de acordos de confidencialidade (NDAs) tanto na admissão quanto na saída, inconsistência nas proteções de segurança para teletrabalho e a falta de um canal eficaz para reporte de eventos suspeitos. Esta situação exige uma atenção imediata e um plano de ação robusto para estabelecer as bases de uma cultura de segurança e garantir a implementação dos controlos essenciais de segurança de recursos humanos.

Figura 44 – Análise de Risco IA

Plano de Ação Corretiva

ISO	Falha Detetada	Solução Recomendada
[A.6.2] As responsabilidades de segurança constam nos contratos de trabalho dos colaboradores?	As responsabilidades de segurança da informação não estão formalmente definidas ou incluídas nos contratos de trabalho dos colaboradores.	Rever e atualizar todos os contratos de trabalho para incluir explicitamente as responsabilidades de segurança da informação relevantes para cada função, garantindo que os colaboradores compreendem as suas obrigações.
[A.6.3] Consegues mostrar os certificados ou registos de presença da última formação de segurança?	Falta de registos auditáveis ou evidências documentadas da participação dos colaboradores em formações de segurança da informação.	Implementar um sistema robusto de registo e gestão de formações de segurança, assegurando a recolha de assinaturas, emissão de certificados ou outros registos formais de presença e conclusão.
[A.6.3] É realizado algum teste de Phishing simulado para medir a consciencialização?	Ausência de testes de phishing simulados regulares para avaliar e melhorar proativamente a consciencialização dos colaboradores sobre ameaças de engenharia social.	Desenvolver e implementar um programa regular de testes de phishing simulados, com follow-up e formação direcionada para os colaboradores que necessitem de reforço.
[A.6.4] Existe um processo disciplinar formal para violações de segurança da informação?	Inexistência de um processo disciplinar formal, documentado e comunicado para lidar com violações das políticas de segurança da informação.	Criar e comunicar um processo disciplinar formal, com diretrizes claras para a resposta a violações de segurança, incluindo as sanções aplicáveis, e garantir a sua aplicação consistente.
[A.6.5] Os colaboradores que rescindem contrato são lembrados formalmente de que os Acordos de Confidencialidade (NDA) continuam válidos?	Falta de um procedimento formal e documentado para lembrar colaboradores em processo de rescisão sobre a continuidade das obrigações de confidencialidade (NDAs).	Integrar no processo de offboarding um lembrete formal, por escrito, sobre a validade contínua dos Acordos de Confidencialidade, obtendo, se possível, uma confirmação de leitura.
[A.6.6] Todos os colaboradores e prestadores de serviços assinaram acordos de confidencialidade (NDA)?	Nem todos os colaboradores e prestadores de serviços têm Acordos de Confidencialidade (NDAs) assinados, expondo a organização a riscos de divulgação de informação.	Assegurar que todos os colaboradores (atuais e futuros) e prestadores de serviços assinem Acordos de Confidencialidade antes do início das suas funções ou prestação de serviços. Fazer um levantamento dos NDAs em falta e proceder à sua regularização.
[A.6.7] Os equipamentos usados em teletrabalho têm as mesmas proteções que os do escritório?	Inconsistência nas proteções de segurança aplicadas a equipamentos usados em teletrabalho em comparação com os equipamentos do escritório, criando vulnerabilidades.	Desenvolver e implementar uma política de segurança para teletrabalho que garanta que os equipamentos remotos possuam as mesmas ou equivalentes proteções de segurança (e.g., antivírus atualizado, patches de segurança, VPN obrigatória, controlo de acesso) que os equipamentos internos.
[A.6.8] Existe um canal fácil e rápido para os funcionários reportarem eventos suspeitos?	Ausência de um canal claro, fácil e rápido para os funcionários reportarem eventos ou atividades suspeitas de segurança, atrasando a resposta a potenciais incidentes.	Estabelecer e comunicar amplamente um canal de comunicação claro e acessível (e.g., endereço de e-mail dedicado, sistema de tickets, linha direta de segurança) para que os funcionários possam reportar incidentes e eventos suspeitos de forma eficiente e sem receios.

Figura 44 – Plano de Ação Corretiva IA

ID do Teste: CT-06

- Requisitos Comprovados: req-09, req-12
- Funcionalidade Testada: Exportação do Relatório Final e Indicadores.
- Dados de Entrada: Comando para download do relatório.
- Resultado Esperado: Geração de um ficheiro PDF (via jsPDF) contendo o score global, o gráfico Donut de conformidade, o resumo da IA e a assinatura manuscrita.
- Resultado Obtido: Sucesso - PDF descarregado com a formatação e gráficos corretos (Cumprimento parcial do req-09 devido à exclusão do CSV).
- Estado: Passou

Detalhes Completos da Avaliação

Controlo Avaliado	Evidência	Resultado	Notas da Auditoria	Plano de Ação
É feita uma verificação de antecedentes (background check, referências) adequada ao nível de risco antes de cada contratação?	-	SIM	falta background check Risco resolvido via Plano de Ação.	-
As responsabilidades de segurança constam nos contratos de trabalho dos colaboradores?	-	NÃO	-	-
Consegues mostrar os certificados ou registos de presença da última formação de segurança?	-	NÃO	-	-
É realizado algum teste de Phishing simulado para medir a consciencialização?	-	NÃO	-	-
Existe um processo disciplinar formal para violações de segurança da informação?	-	NÃO	-	-
Os colaboradores que rescindem contrato são lembrados formalmente de que os Acordos de Confidencialidade (NDA) continuam válidos?	-	NÃO	-	-
Todos os colaboradores e prestadores de serviços assinaram acordos de confidencialidade (NDA)?	-	NÃO	-	-
Os equipamentos usados em teletrabalho têm as mesmas proteções que os do escritório?	-	NÃO	-	-
Existe um canal fácil e rápido para os funcionários reportarem eventos suspeitos?	-	NÃO	-	-

Validação e Assinatura do Auditor:



Empresa Auditada	NOS
Número do Documento	AUD-0020
Conduzido por	Daniel Filipe Ramos de Carvalho (dawdawasetfd@gmail.com)
Conduzido em	12/05/2026
Relatório Auditoria ISO 27001 Página 1 de 3	

Concluído em	Pendente
Norma de Referência	ISO/IEC 27001:2022
Estado da Auditoria	Em curso
Resultado Global	0%



Figura 55 , 46 , 47 - Evidencias caso de teste CT-06

GRUPO 4: Dashboards, Riscos e Evidências

ID do Teste: CT-07

- Requisitos Comprovados: req-10, req-11
- Funcionalidade Testada: Visualização de Dashboard e Filtros de Conformidade.
- Dados de Entrada: Acesso à página Dashboard e interações com os domínios.
- Resultado Esperado: Apresentação gráfica do Score de Risco, barra de progresso do SoA e métricas da última auditoria.
- Resultado Obtido: Sucesso - Dados são carregados corretamente da API e renderizados visualmente.
- Estado: Passou

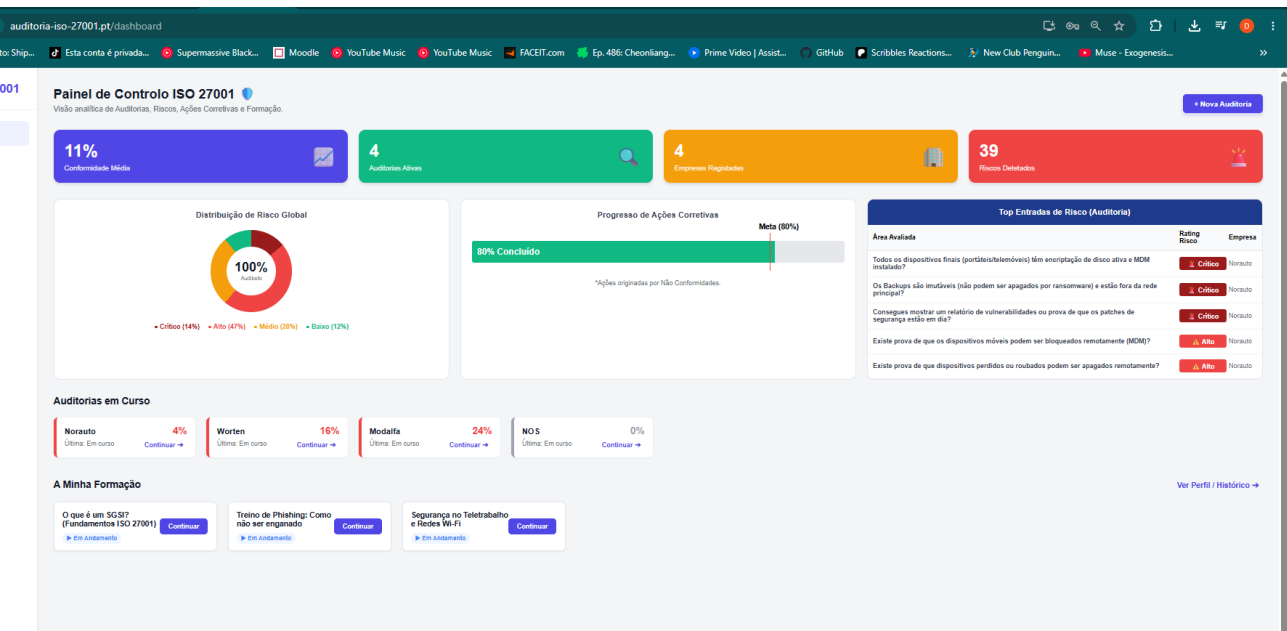
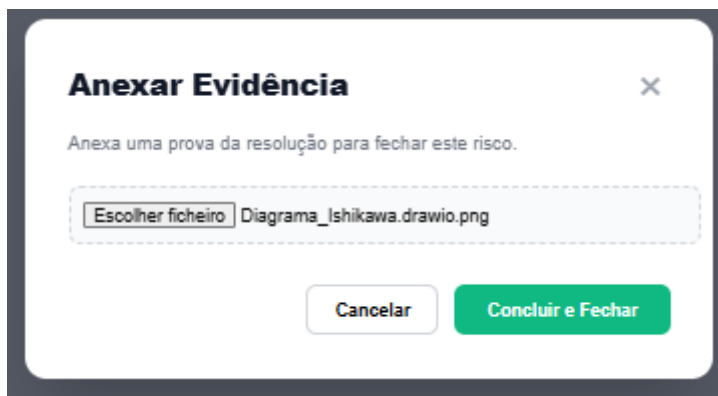
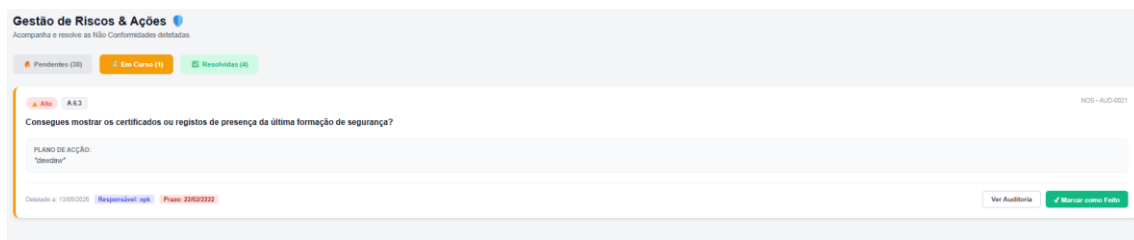


Figura 48 – Evidencia Caso de teste CT-07

ID do Teste: CT-08

- Requisitos Comprovados: req-20
- Funcionalidade Testada: Tratamento de Riscos e Upload de Evidências.
- Dados de Entrada: Acesso à página de Riscos, seleção de um risco "Pendente" e upload de um ficheiro (ex: PDF ou Imagem).
- Resultado Esperado: O ficheiro é enviado para o bucket (Media), o risco passa ao estado "Concluído" e a ação corretiva é fechada.
- Resultado Obtido: Sucesso - Evidência guardada no servidor e UI atualizada para refletir o novo estado.
- Estado: Passou



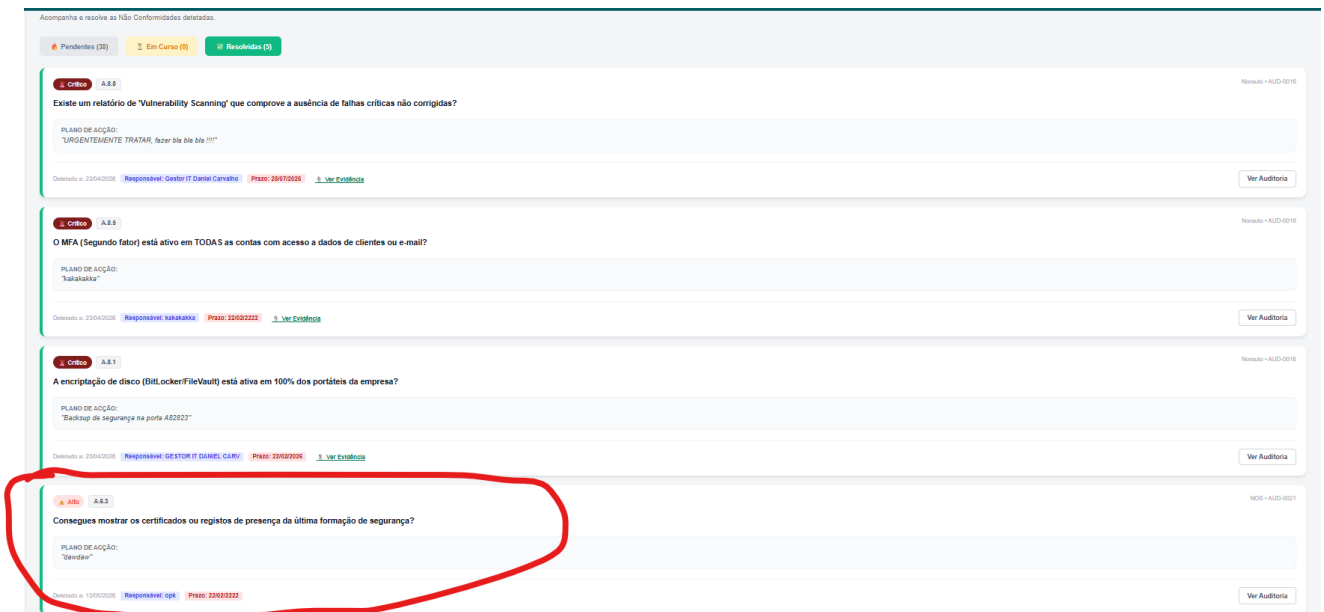
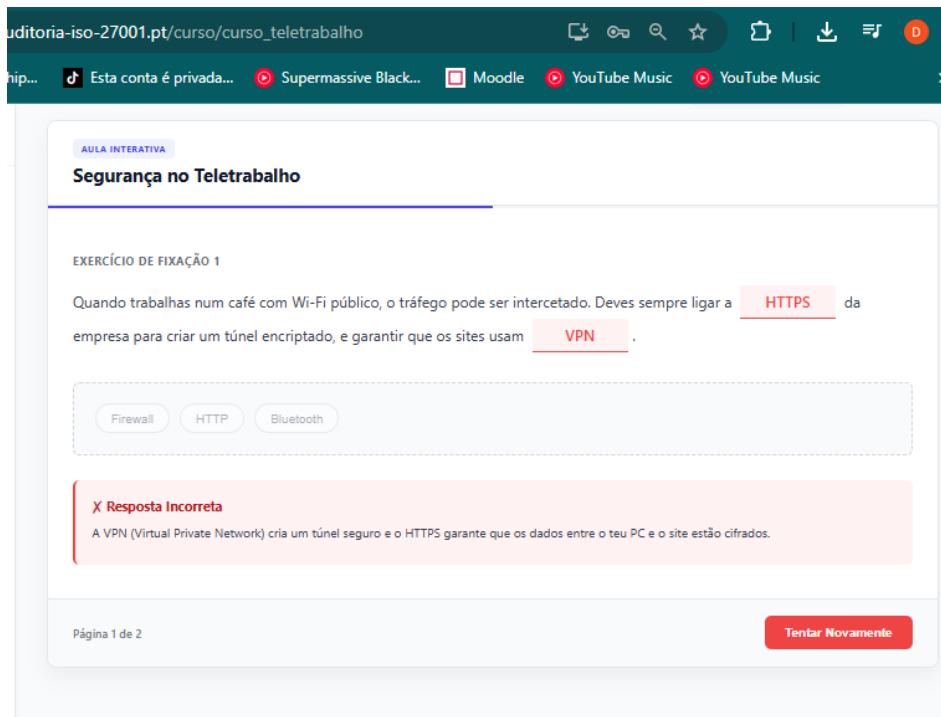


Figura 49 – Evidências Caso de teste CT-08, ao por uma evidencia ele vai para os resolvidos

GRUPO 5: Formação Interativa (E-Learning)

ID do Teste: CT-09

- Requisitos Comprovados: req-13, req-14, req-21
- Funcionalidade Testada: Realização de Curso Interativo e Tracking de Progresso.
- Dados de Entrada: Preenchimento dos espaços em branco (quizzes) no módulo de "Teletrabalho" com respostas certas e erradas.
- Resultado Esperado: O sistema dá feedback imediato em tempo real, impede o avanço em caso de erro e regista o módulo como "Concluído" no perfil no final.
- Resultado Obtido: Sucesso - Lógica de validação em frontend funciona na perfeição e o progresso é salvo no perfil do utilizador via API.
- Estado: Passou



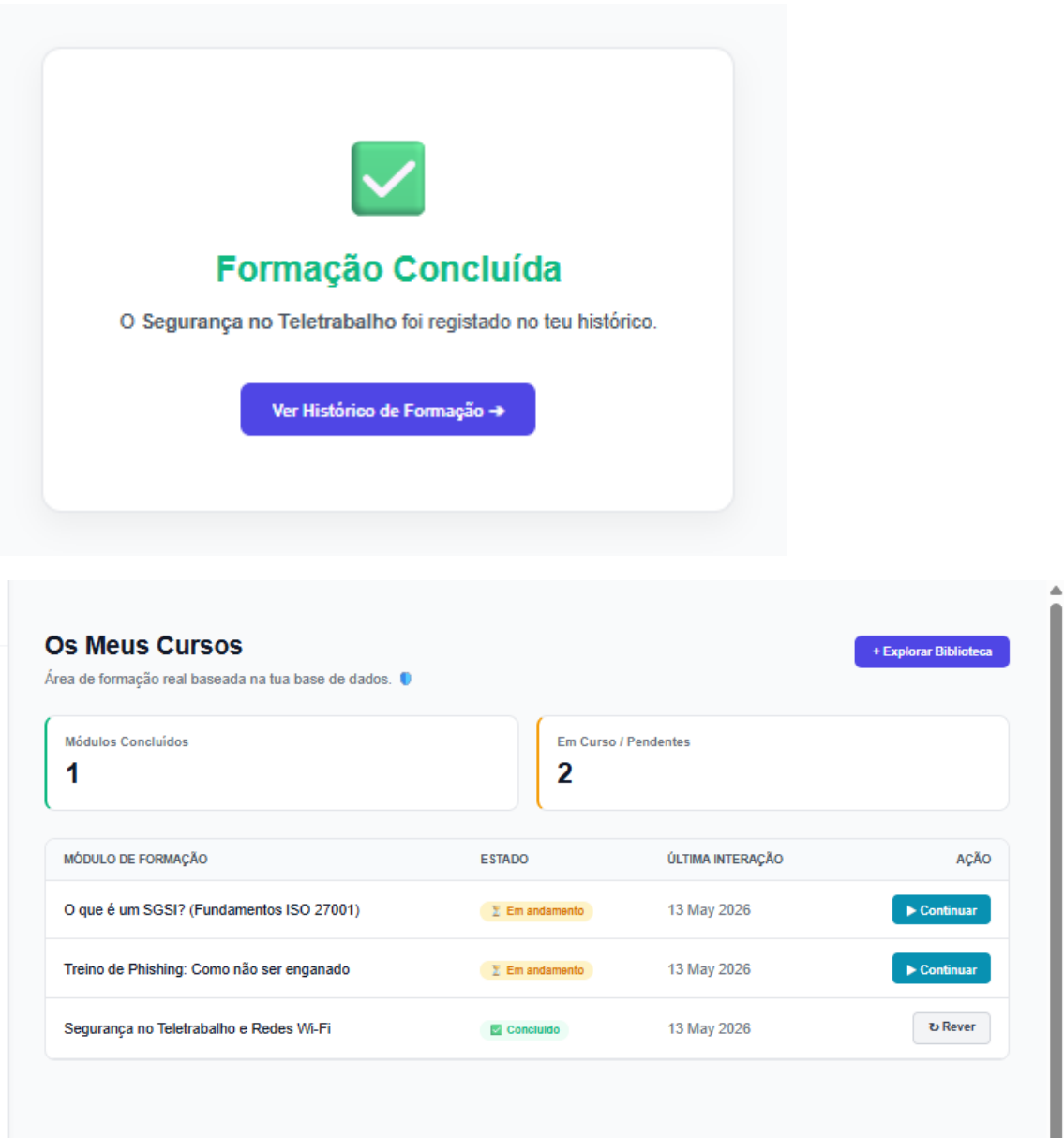
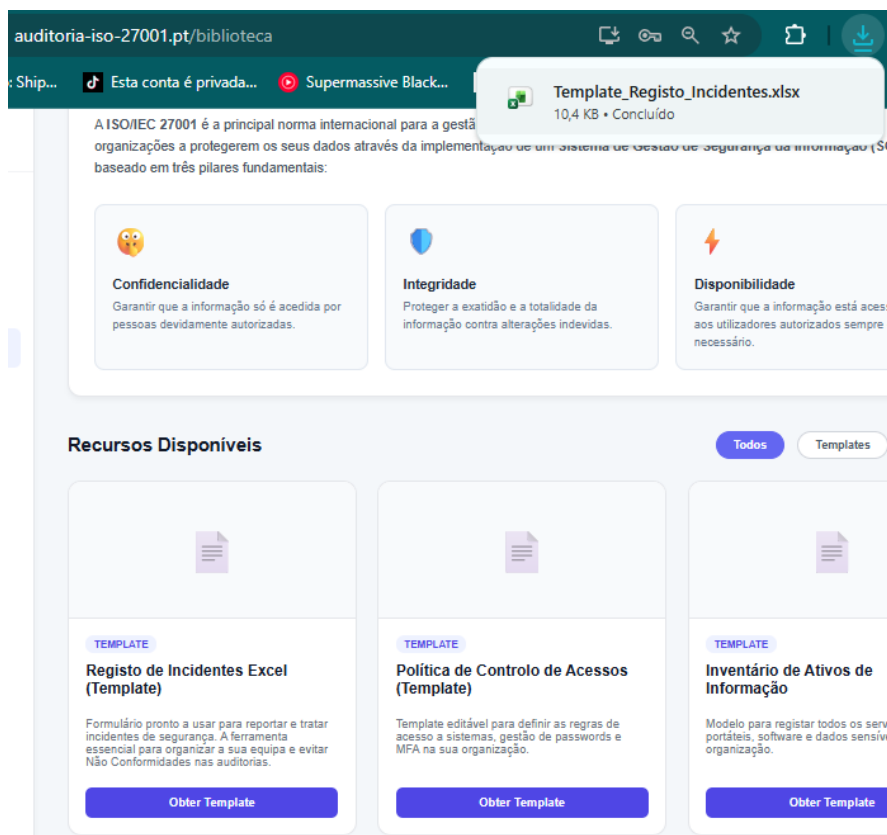


Figura 60, 51, 52 ,53 – Evidencias Caso de teste CT-09 , ao completar uma formação ela aparece como concluída

ID do Teste: CT-10

- Requisitos Comprovados: req-16
- Funcionalidade Testada: Acesso à Biblioteca e Download de Templates.
- Dados de Entrada: Clique num recurso do tipo "Documento" (Ex: Política de Controlo de Acessos).
- Resultado Esperado: Abertura do link externo ou download direto do ficheiro Word/PDF de template.
- Resultado Obtido: Sucesso - Documentação transferida corretamente.
- Estado: Passou



eca

Supermassive Black...

Template_Secretaria_Limpa.docx

16,3 KB • Concluído

Principal norma internacional para a gestão dos seus dados através da implementação de um sistema de Gestão de Segurança da Informação (SGSI) fundamentais:

Integridade

Proteger a exatidão e a totalidade da informação contra alterações indevidas.

Disponibilidade

Garantir que a informação está acessível aos utilizadores autorizados sempre que necessário.

is

Todos

Templates

Excel

Reportar e tratar incidentes de segurança, monitorizar a atividade da equipa e evitar violações.

Obter Template

Política de Controlo de Acessos (Template)

Template editável para definir as regras de acesso a sistemas, gestão de passwords e MFA na sua organização.

Obter Template

Inventário de Ativos de Informação

Modelo para registar todos os serviços, equipamentos, software e dados sensíveis da organização.

Obter Template

Segurança

Controlos do Anexo A da norma ISO 27001 para a sua empresa.

Obter Template

Política de Secretária Limpa e Ecrã Bloqueado

Normas físicas para evitar exposição de documentos confidenciais no escritório.

Obter Template

Segurança no Teletrabalho e Redes Wi-Fi

Boas práticas para proteger a informação da empresa quando trabalha a partir de casa ou em espaços públicos.

Assistir / Treinar

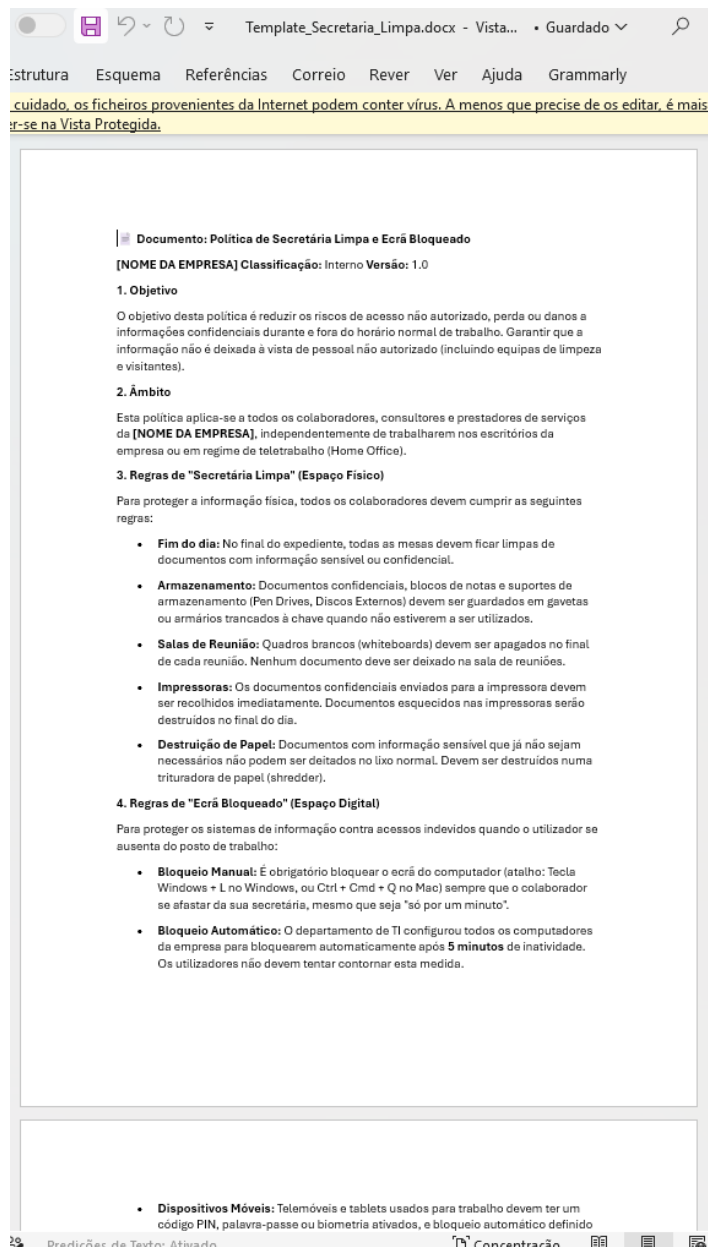


Figura 54. 55, 56 – Evidências Caso de teste CT-10, faz download dos templates, 56 é um exemplo dum template

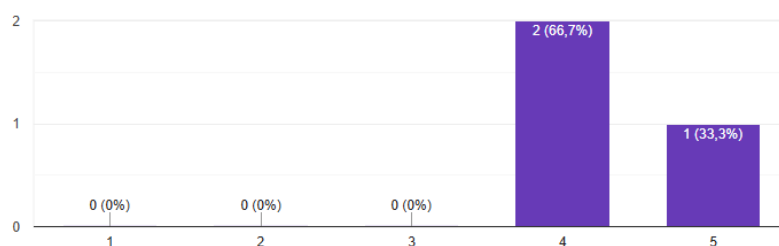
Anexo II — Avaliação por Terceiros e Resultados dos Inquéritos (UAT)

https://docs.google.com/forms/d/1HQJv_BtrNDJASU0mN-q09eurZftVa6oDNgELV178KJE/edit#responses

Aqui se encontra o feedback das pessoas que responderam ao questionário sobre a Plataforma “Auditoria ISO 27001”

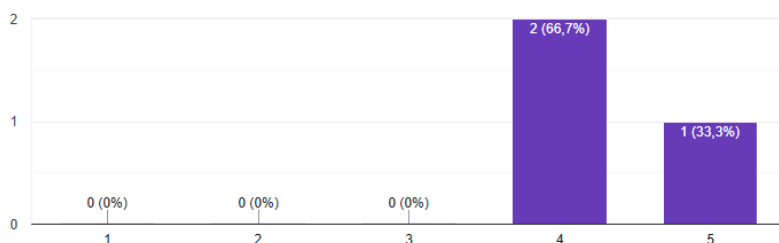
Usabilidade: Quão fácil e intuitiva foi a navegação na plataforma (ex: menus, Dashboard, Checklist)? (Escala 1 a 5) [Copiar gráfico](#)

3 respostas



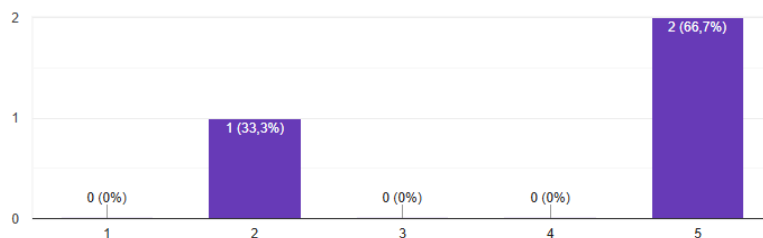
Funcionalidade de IA: A sugestão do Plano de Ação gerada pela Inteligência Artificial fez sentido e pareceu-te útil? (Escala 1 a 5) [Copiar gráfico](#)

3 respostas



Módulo de Formação: O curso interativo (com preenchimento de espaços) foi claro e funcionou bem? (Escala 1 a 5) [Copiar gráfico](#)

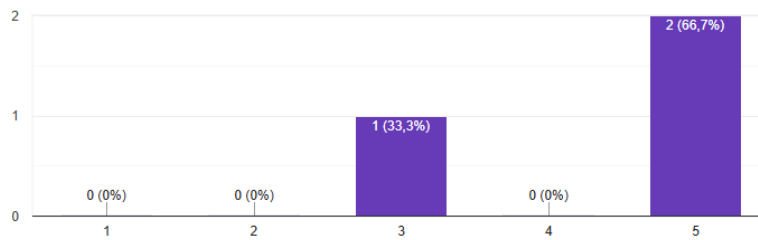
3 respostas



Dashboard e Monitorização (SoA): A visualização do Dashboard SoA (cartões verdes/vermelhos e barra de progresso) permitiu-te perceber facilmente o estado de conformidade das empresas? (Escala 1 a 5)

 Copiar gráfico

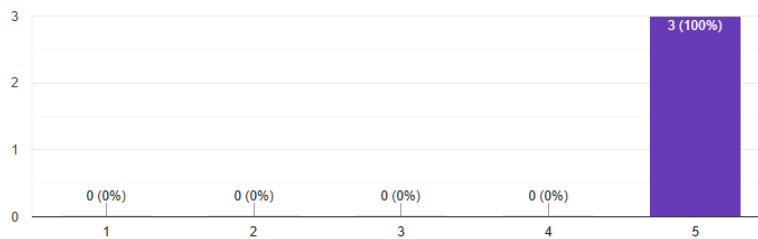
3 respostas



Motor de Auditoria e Assinatura Digital: O preenchimento da checklist da norma ISO e a capacidade de assinar o documento diretamente no ecrã funcionaram de forma fluida?

 Copiar gráfico

3 respostas



Impacto no Negócio (Tempo): Na tua opinião, utilizar esta plataforma reduz o tempo despendido numa auditoria face ao método tradicional (pastas partilhadas, papel e ficheiros de Excel)?

3 respostas

sim

Sim claro que sim

Sim

Comentários Finais: Qual foi a funcionalidade que mais te impressionou ou que aspeto achas que poderia ser melhorado no futuro?

3 respostas

A Automação do Relatório PDF com IA; futuro - Aplicação Mobile Nativa

Não sei

Todas